

SERVIZI DI FORMAZIONE

**Materiale per i partecipanti per ISO/IEC 42001:2023
Tecnologia dell'informazione — Intelligenza artificiale — Sistema di gestione**

Anno di emissione: 2023

<https://www.dnv.com/assurance>



AVVISO DI COPYRIGHT E AUTORIZZAZIONE ALL'USO

Questo documento è stato prodotto da SAI Global con l'autorizzazione di AENOR. La riproduzione totale o parziale dei documenti PDF è vietata.

SAI Global non fornisce alcuna garanzia circa la correttezza del documento o i risultati derivanti dall'acquisto e dall'utilizzo del documento e non è responsabile per eventuali problemi nella consegna del documento. Per qualsiasi difficoltà o domanda, rivolgersi a SAI Global.

Permesso di utilizzo

È possibile scaricare e visualizzare un file elettronico di questa pubblicazione standard per l'archiviazione temporanea su un dispositivo elettronico ai fini della partecipazione a un programma di formazione e certificazione offerto da una società di DNV Business Assurance. È inoltre possibile stampare una copia della pubblicazione standard in relazione al programma di formazione e certificazione offerto da DNV Business Assurance. Al di fuori di questo utilizzo consentito, né il file elettronico né la copia cartacea possono essere riprodotti o distribuiti in alcun modo, nemmeno all'interno della propria organizzazione o ad altri partecipanti a un corso DNV.

INTERNAZIONALE STANDARD

**ISO/IEC
42001**

Prima edizione
2023-12

Tecnologia dell'informazione — Intelligenza artificiale — Sistema di gestione

*Tecnologie dell'informazione — Intelligenza artificiale — Sistema
di gestione*

COURSE COPY



Numero di riferimento
ISO/IEC 42001:2023(E)

© ISO/IEC 2023

ISO/IEC 42001:2023(E)



DOCUMENTO PROTETTO DA COPYRIGHT

© ISO/IEC 2023.

Tutti i diritti riservati. Salvo diversa indicazione o richiesta nel contesto della sua implementazione, nessuna parte di questa pubblicazione può essere riprodotta o utilizzata in alcun modo, in alcuna forma o con alcun mezzo, elettronico o meccanico, inclusa la fotocopia, o la pubblicazione su Internet o intranet, senza previa autorizzazione scritta. L'autorizzazione può essere richiesta all'ISO all'indirizzo sotto indicato o all'organismo membro dell'ISO nel paese del richiedente.

Ufficio copyright ISO CP
401 • Ch. de Blandonnet 8 CH-1214

Vernier, Ginevra Telefono: +41
22 749 01 11 E-mail:

copyright@iso.org Sito web:
www.iso.org

Pubblicato in Svizzera

Contenuto

Pagina

Prefazione.....v

Introduzione.....vi

1 Ambito di applicazione.....1

2 Riferimenti **normativi**1

3 **Termini e definizioni**.....1

4 **Contesto dell'organizzazione**5

4.1 Comprendere l'organizzazione e il suo contesto..... 5

4.2 Comprendere le esigenze e le aspettative delle parti interessate..... 6

4.3 Determinazione dell'ambito del sistema di gestione dell'IA..... 6

4.4 Sistema di gestione dell'IA..... 6

5 Leadership.....7

5.1 Leadership e impegno..... 7

5.2 Politica in materia di IA..... 7

5.3 Ruoli, responsabilità e autorità..... 8

6 Pianificazione.....8

6.1 Azioni per affrontare rischi e opportunità 8

6.1.1 Generale..... 8

6.1.2 Valutazione del rischio dell'IA..... 9

6.1.3 Trattamento del rischio di IA..... 9

6.1.4 Valutazione dell'impatto del sistema di intelligenza artificiale 10

6.2 Obiettivi dell'IA e pianificazione per raggiungerli 10

6.3 Pianificazione dei cambiamenti11

7 Supporto.....11

7.1 Risorse11

7.2 Competenza.....11

7.3 Consapevolezza.....12

7.4 Comunicazione.....12

7.5 Informazioni documentate12

7.5.1 Generale.....12

7.5.2 Creazione e aggiornamento delle informazioni documentate.....12

7.5.3 Controllo delle informazioni documentate.....13

8 Operazione.....13

8.1 Pianificazione e controllo operativo13

8.2 Valutazione del rischio dell'IA.....13

8.3 Trattamento del rischio di IA..... 14

8.4 Valutazione dell'impatto del sistema di intelligenza artificiale 14

9 **Valutazione delle prestazioni**14

9.1 Monitoraggio, misurazione, analisi e valutazione..... 14

9.2 Audit interno..... 14

9.2.1 Generale..... 14

9.2.2 Programma di audit interno 14

9.3 Revisione della direzione.....15

9.3.1 Generale.....15

9.3.2 Input di revisione della direzione15

9.3.3 Risultati della revisione della direzione.....15

10 Miglioramento.....15

10.1 Miglioramento continuo.....15

10.2 Non conformità e azioni correttive..... 16

Allegato A (normativo) Obiettivi e controlli di riferimento.....17

ISO/IEC 42001:2023 Standard distributed by SAI Global underlicensed via AENOR to be used by delegates of a DNV Course

ISO/IEC 42001:2023(E)

Allegato B (normativo) **Linee guida per l'implementazione dei controlli dell'IA**21

Allegato C (informativo) **Potenziali obiettivi organizzativi e fonti di rischio correlati all'IA**46 **Allegato D**

(informativo) **Utilizzo del sistema di gestione dell'IA in diversi ambiti o settori**49

Bibliografia.....

ISO/IEC 42001:2023 Standard distributed by SAI Global underlicensed via AENOR to be used by delegates of a DNV Course

Prefazione

L'ISO (Organizzazione Internazionale per la Normazione) e l'IEC (Commissione Elettrotecnica Internazionale) costituiscono il sistema specializzato per la normazione mondiale. Gli organismi nazionali membri dell'ISO o dell'IEC partecipano allo sviluppo delle norme internazionali attraverso comitati tecnici istituiti dalle rispettive organizzazioni per occuparsi di specifici campi di attività tecnica. I comitati tecnici dell'ISO e dell'IEC collaborano in settori di interesse comune. Anche altre organizzazioni internazionali, governative e non governative, in collaborazione con l'ISO e l'IEC, partecipano ai lavori.

Le procedure utilizzate per lo sviluppo del presente documento e quelle previste per la sua ulteriore manutenzione sono descritte nelle Direttive ISO/IEC, Parte 1. In particolare, si segnalano i diversi criteri di approvazione necessari per le diverse tipologie di documento. Il presente documento è stato redatto in conformità con le norme editoriali delle Direttive ISO/IEC, Parte 2 (vedere www.iso.org/directives), o www.iec.ch/members_experts/refdocs).

ISO e IEC richiamano l'attenzione sulla possibilità che l'implementazione del presente documento possa comportare l'uso di brevetti. ISO e IEC non prendono posizione in merito all'evidenza, alla validità o all'applicabilità di eventuali diritti brevettuali rivendicati in relazione a tale documento. Alla data di pubblicazione del presente documento, ISO e IEC non avevano ricevuto notifica di brevetti che potrebbero essere necessari per l'implementazione del presente documento. Tuttavia, si avvisano gli implementatori che queste informazioni potrebbero non essere aggiornate, e che possono essere reperite nel database dei brevetti disponibile agli indirizzi www.iso.org/patents e <https://patents.iec.ch>. ISO e IEC non saranno ritenute responsabili dell'identificazione di alcuno o di tutti tali diritti brevettuali.

Tutti i nomi commerciali utilizzati nel presente documento sono informazioni fornite a scopo di comodità degli utenti e non costituiscono un'approvazione.

Per una spiegazione della natura volontaria delle norme, del significato dei termini e delle espressioni specifici ISO relativi alla valutazione della conformità, nonché per informazioni sull'adesione dell'ISO ai principi dell'Organizzazione Mondiale del Commercio (OMC) nell'ambito degli ostacoli tecnici al commercio (OTC), si veda www.iso.org/iso/foreword.html. Per quanto riguarda la IEC, si veda www.iec.ch/understanding-standards.

Il presente documento è stato redatto dal Comitato tecnico congiunto ISO/IEC JTC 1, *Tecnologia dell'informazione*, Sottocomitato SC 42, *Intelligenza artificiale*.

Eventuali commenti o domande su questo documento devono essere indirizzati all'organismo di normazione nazionale dell'utente. Un elenco completo di questi organismi è disponibile all'indirizzo www.iso.org/members.html e www.iec.ch/national-committees.

Introduzione

L'intelligenza artificiale (IA) è sempre più applicata in tutti i settori che utilizzano le tecnologie dell'informazione e si prevede che diventerà uno dei principali motori economici. Una conseguenza di questa tendenza è che alcune applicazioni potrebbero dare origine a sfide sociali nei prossimi anni.

Questo documento intende aiutare le organizzazioni a svolgere responsabilmente il proprio ruolo nell'ambito dei sistemi di intelligenza artificiale (ad esempio, nell'utilizzo, nello sviluppo, nel monitoraggio o nella fornitura di prodotti o servizi che utilizzano l'intelligenza artificiale). L'intelligenza artificiale solleva potenzialmente considerazioni specifiche, come:

- L'uso dell'intelligenza artificiale per processi decisionali automatici, talvolta in modo non trasparente e non spiegabile, può richiedere una gestione specifica che va oltre la gestione dei sistemi IT classici.
- L'uso dell'analisi dei dati, della comprensione e dell'apprendimento automatico, anziché della logica codificata dall'uomo, per progettare sistemi aumenta le opportunità di applicazione dei sistemi di intelligenza artificiale e cambia il modo in cui tali sistemi vengono sviluppati, giustificati e implementati.
- I sistemi di intelligenza artificiale che eseguono un apprendimento continuo modificano il loro comportamento durante l'uso. Richiedono particolare attenzione per garantire che il loro utilizzo responsabile continui a comportarsi in modo diverso.

Questo documento fornisce i requisiti per l'istituzione, l'implementazione, il mantenimento e il miglioramento continuo di un sistema di gestione dell'IA nel contesto di un'organizzazione. Le organizzazioni sono tenute a concentrare l'applicazione dei requisiti sulle caratteristiche specifiche dell'IA. Alcune caratteristiche dell'IA, come la capacità di apprendere e migliorare costantemente o la mancanza di trasparenza o spiegabilità, possono giustificare misure di salvaguardia diverse se sollevano ulteriori preoccupazioni rispetto alle modalità di esecuzione tradizionali. L'adozione di un sistema di gestione dell'IA per ampliare le strutture di gestione esistenti è una decisione strategica per un'organizzazione.

Le esigenze e gli obiettivi dell'organizzazione, i processi, le dimensioni e la struttura, nonché le aspettative delle diverse parti interessate, influenzano l'istituzione e l'implementazione del sistema di gestione dell'IA. Un altro insieme di fattori che influenzano l'istituzione e l'implementazione del sistema di gestione dell'IA sono i numerosi casi d'uso dell'IA e la necessità di trovare il giusto equilibrio tra meccanismi di governance e innovazione. Le organizzazioni possono scegliere di applicare questi requisiti utilizzando un approccio basato sul rischio per garantire che venga applicato il livello di controllo appropriato per i specifici casi d'uso, servizi o prodotti di IA nell'ambito dell'organizzazione. È previsto che tutti questi fattori influenti cambino e vengano rivisti periodicamente.

Il sistema di gestione dell'IA dovrebbe essere integrato con i processi e la struttura gestionale complessiva dell'organizzazione. Nella progettazione di processi, sistemi informativi e controlli, è necessario considerare le problematiche specifiche relative all'IA. Esempi cruciali di tali processi di gestione sono:

- determinazione degli obiettivi organizzativi, coinvolgimento delle parti interessate e politica;
- gestione dei rischi e delle opportunità;
- processi per la gestione delle preoccupazioni relative all'affidabilità dei sistemi di intelligenza artificiale, quali sicurezza, protezione, equità, trasparenza, qualità dei dati e qualità dei sistemi di intelligenza artificiale durante tutto il loro ciclo di vita;
- processi per la gestione di fornitori, partner e terze parti che forniscono o sviluppano sistemi di intelligenza artificiale per l'organizzazione.

Il presente documento fornisce linee guida per l'implementazione di controlli applicabili a supporto di tali processi.

Il presente documento non fornisce indicazioni specifiche sui processi di gestione. L'organizzazione può combinare framework generalmente accettati, altri standard internazionali e la propria esperienza per implementare processi cruciali come la gestione del rischio, la gestione del ciclo di vita e la gestione della qualità dei dati, appropriati per gli specifici casi d'uso, prodotti o servizi di IA inclusi nell'ambito di applicazione.

Un'organizzazione che rispetta i requisiti del presente documento può fornire prova della propria responsabilità e rendicontazione in merito al proprio ruolo nei sistemi di intelligenza artificiale.

L'ordine in cui i requisiti sono presentati in questo documento non ne riflette l'importanza né implica l'ordine in cui vengono implementati. Le voci dell'elenco sono elencate solo a scopo di riferimento.

Compatibilità con altri standard di sistemi di gestione

Il presente documento applica la struttura armonizzata (numeri di clausola, titoli di clausola, testo e termini comuni e definizioni fondamentali identici) sviluppata per migliorare l'allineamento tra gli standard dei sistemi di gestione (MSS). Il sistema di gestione dell'IA fornisce requisiti specifici per la gestione delle problematiche e dei rischi derivanti dall'utilizzo dell'IA in un'organizzazione. Questo approccio comune facilita l'implementazione e la coerenza con altri standard dei sistemi di gestione, ad esempio relativi a qualità, sicurezza, protezione e privacy.

Tecnologia dell'informazione — Intelligenza artificiale — Sistema di gestione

1 Ambito di applicazione

Il presente documento specifica i requisiti e fornisce indicazioni per l'istituzione, l'implementazione, la manutenzione e il miglioramento continuo di un sistema di gestione dell'IA (intelligenza artificiale) nel contesto di un'organizzazione.

Il presente documento è destinato a un'organizzazione che fornisce o utilizza prodotti o servizi che utilizzano sistemi di intelligenza artificiale. Il presente documento ha lo scopo di aiutare l'organizzazione a sviluppare, fornire o utilizzare sistemi di intelligenza artificiale in modo responsabile, perseguendo i propri obiettivi e soddisfacendo i requisiti applicabili, gli obblighi relativi alle parti interessate e le aspettative da esse derivanti.

Il presente documento è applicabile a qualsiasi organizzazione, indipendentemente da dimensioni, tipologia e natura, che fornisca o utilizzi prodotti o servizi che utilizzano sistemi di intelligenza artificiale.

2 Riferimenti normativi

I seguenti documenti sono citati nel testo in modo tale che parte o tutto il loro contenuto costituisca requisiti del presente documento. Per i riferimenti datati, si applica solo l'edizione citata. Per i riferimenti non datati, si applica l'ultima edizione del documento a cui si fa riferimento (inclusi eventuali emendamenti).

ISO/IEC 22989:2022, *Tecnologia dell'informazione — Intelligenza artificiale — Concetti e terminologia dell'intelligenza artificiale*

3 Termini e definizioni

Ai fini del presente documento si applicano i termini e le definizioni riportati nella norma ISO/IEC 22989 e seguenti.

L'ISO e l'IEC gestiscono database terminologici da utilizzare nella standardizzazione ai seguenti indirizzi:

— Piattaforma di navigazione online ISO: disponibile su <https://www.iso.org/obp>

— IEC Electropedia: disponibile su <https://www.electropedia.org/>

3.1

organizzazione

persona o gruppo di persone che ha funzioni proprie con responsabilità, autorità e relazioni per raggiungere i propri *obiettivi* (3.6)

Nota 1 alla voce: Il concetto di organizzazione include, ma non è limitato a, ditta individuale, società, corporazione, ditta, impresa, autorità, partnership, ente di beneficenza o istituzione o parte o combinazione di esse, costituite o meno, pubbliche o private.

Nota 2 alla voce: Se l'organizzazione fa parte di un'entità più grande, il termine "organizzazione" si riferisce solo alla parte dell'entità più grande che rientra nell'ambito del *sistema di gestione* dell'IA (3.4).

3.2

parte interessata

persona o *organizzazione* (3.1) che può influenzare, essere influenzata o percepire se stessa come influenzata da una decisione o attività

Nota 1 alla voce: Una panoramica delle parti interessate all'IA è fornita nella norma ISO/IEC 22989:2022, 5.19.

ISO/IEC 42001:2023(E)

3.3

alta dirigenza

persona o gruppo di persone che dirige e controlla un'organizzazione (3.1) al livello più alto

Nota 1 alla voce: L'alta dirigenza ha il potere di delegare autorità e fornire risorse all'interno dell'organizzazione.

Nota 2 alla voce: Se l'ambito del *sistema di gestione* (3.4) copre solo una parte di un'organizzazione, allora l'alta direzione si riferisce a coloro che dirigono e controllano quella parte dell'organizzazione.

3.4

sistema di gestione

insieme di elementi interrelati o interagenti di un'organizzazione (3.1) per stabilire *politiche* (3.5) e *obiettivi* (3.6), nonché *processi* (3.8) per raggiungere tali obiettivi

Nota 1 alla voce: Un sistema di gestione può riguardare una singola disciplina o più discipline.

Nota 2 alla voce: Gli elementi del sistema di gestione includono la struttura, i ruoli e le responsabilità, la pianificazione e il funzionamento dell'organizzazione.

3.5

politica

intenzioni e direzione di un'organizzazione (3.1) come formalmente espresse dal suo *top management* (3.3)

3.6

obiettivo

risultato da raggiungere

Nota 1 alla voce: Un obiettivo può essere strategico, tattico o operativo.

Nota 2 alla voce: gli obiettivi possono riguardare discipline diverse (ad esempio finanza, salute e sicurezza e ambiente). Possono essere, ad esempio, a livello di organizzazione o specifici di un progetto, prodotto o *processo* (3.8).

Nota 3 alla voce: Un obiettivo può essere espresso in altri modi, ad esempio come risultato previsto, come scopo, come criterio operativo, come obiettivo di intelligenza artificiale o mediante l'uso di altre parole con significato simile (ad esempio scopo, traguardo o bersaglio).

Nota 4 alla voce: Nel contesto dei *sistemi di gestione dell'IA* (3.4), gli *obiettivi* dell'IA sono stabiliti dall'organizzazione (3.1), in *linea* con la *politica* dell'IA (3.5), per raggiungere risultati specifici.

3.7

rischio

effetto dell'incertezza

Nota 1 alla voce: Un effetto è una deviazione da quanto previsto, positiva o negativa.

Nota 2 alla voce: L'incertezza è lo stato, anche parziale, di carenza di informazioni relative alla comprensione o alla conoscenza di un evento, delle sue conseguenze o della sua probabilità.

Nota 3 alla voce: Il rischio è spesso caratterizzato dal riferimento a potenziali eventi (come definiti nella Guida ISO 73) e conseguenze (come definiti nella Guida ISO 73), o una combinazione di questi.

Nota 4 alla voce: Il rischio è spesso espresso in termini di combinazione delle conseguenze di un evento (inclusi i cambiamenti nelle circostanze) e della probabilità associata (come definita nella Guida ISO 73) del verificarsi dell'evento.

3.8

processo

insieme di attività interrelate o interagenti che utilizzano o trasformano gli input per fornire un risultato

Nota 1 alla voce: Se il risultato di un processo sia definito output, prodotto o servizio dipende dal contesto del riferimento.

3.9**competenza**

capacità di applicare conoscenze e abilità per raggiungere i risultati attesi

3.10**informazioni documentate**

informazioni che devono essere controllate e mantenute da un'organizzazione (3.1) e il supporto su cui sono contenute

Nota 1 alla voce: Le informazioni documentate possono essere in qualsiasi formato, su qualsiasi supporto e provenienti da qualsiasi fonte.

Nota 2 alla voce: Le informazioni documentate possono fare riferimento a:

- il *sistema di gestione* (3.4), compresi i *processi correlati* (3.8);
- informazioni create affinché l'organizzazione possa operare (documentazione);
- prove dei risultati conseguiti (registrazioni).

3.11**risultato misurabile della prestazione**

Nota 1 alla voce: la performance può essere correlata a risultati quantitativi o qualitativi.

Nota 2 alla voce: La performance può riferirsi alla gestione di attività, *processi* (3.8), prodotti, servizi, *sistemi* o *organizzazioni* (3.1).

Nota 3 alla voce: Nel contesto del presente documento, per performance si intendono sia i risultati ottenuti utilizzando sistemi di IA sia i risultati relativi al *sistema di gestione* dell'IA (3.4). La corretta interpretazione del termine è chiara dal contesto del suo utilizzo.

3.12**miglioramento continuo** attività

ricorrente per migliorare *le prestazioni* (3.11)

3.13**efficacia** misura in

cui le attività pianificate vengono realizzate e i risultati pianificati vengono conseguiti

3.14**requisito** ,

necessità o aspettativa dichiarata, generalmente implicita o obbligatoria

Nota 1 alla voce: "Generalmente implicito" significa che è consuetudine o prassi comune per l' *organizzazione* (3.1) e le *parti interessate* (3.2) che la necessità o l'aspettativa in esame sia implicita.

Nota 2 alla voce: Un requisito specificato è un requisito che è dichiarato, ad esempio, in *informazioni documentate* (3.10).

3.15**conformità**

adempimento di un *requisito* (3.14)

3.16**non conformità**

inadempimento di un *requisito* (3.14)

3.17**azione correttiva** azione

volta ad eliminare la/le causa/e di una *non conformità* (3.16) e a prevenire il ripetersi

ISO/IEC 42001:2023(E)

3.18

audit

processo sistematico e indipendente (3.8) per ottenere prove e valutarle oggettivamente per determinare in quale misura i criteri di audit sono soddisfatti

Nota 1 alla voce: Un audit può essere un audit interno (di prima parte) o un audit esterno (di seconda parte o di terza parte) e può essere un audit combinato (che combina due o più discipline).

Nota 2 alla voce: Un audit interno è condotto dall'organizzazione (3.1) stessa, o da una parte esterna per suo conto.

Nota 3 alla voce: "Evidenze di audit" e "criteri di audit" sono definiti nella norma ISO 19011.

3.19

misurazione

processo (3.8) per determinare un valore

3.20

monitoraggio

determinazione dello stato di un sistema, di un processo (3.8) o di un'attività

Nota 1 alla voce: Per determinare lo stato, potrebbe essere necessario controllare, supervisionare o osservare criticamente.

3.21

controllo

<rischio> misura che mantiene e/o modifica il rischio (3.7) _____

Nota 1 alla voce: I controlli includono, ma non sono limitati a, qualsiasi processo, politica, dispositivo, pratica o altre condizioni e/o azioni che mantengono e/o modificano il rischio.

Nota 2 alla voce: i controlli potrebbero non sempre esercitare l'effetto modificativo previsto o presunto.

[FONTE: ISO 31000:2018, 3.8, modificato — Aggiunto <rischio> come dominio applicativo]

3.22

organo di governo

persona o gruppo di persone responsabili delle prestazioni e della conformità dell'organizzazione

Nota 1 alla voce: Non tutte le organizzazioni, in particolare quelle di piccole dimensioni, hanno un organo di governo separato dal top management.

Nota 2 alla voce: Un organo di governo può includere, ma non è limitato a, consiglio di amministrazione, comitati del consiglio, consiglio di sorveglianza, fiduciari o supervisori.

[FONTE: ISO/IEC 38500:2015, 2.9, modificata — Note aggiunte alla voce.]

3.23

sicurezza delle informazioni

salvaguardia della riservatezza, integrità e disponibilità delle informazioni

Nota 1 alla voce: Possono essere coinvolte anche altre proprietà quali autenticità, responsabilità, non ripudio e affidabilità.

[FONTE: ISO/IEC 27000:2018, 3.28]

3.24

Valutazione dell'impatto del sistema di

intelligenza artificiale: processo formale e documentato mediante il quale gli impatti sugli individui, sui gruppi di individui o su entrambi e sulle società vengono identificati, valutati e affrontati da un'organizzazione che sviluppa, fornisce o utilizza prodotti o servizi che utilizzano l'intelligenza artificiale.

3.25**qualità dei dati**

caratteristica dei dati che i dati soddisfano i requisiti di dati dell'organizzazione per un contesto specifico

[FONTE: ISO/IEC 5259-1:—1), 3.4]

3.26**dichiarazione di applicabilità**

documentazione di tutti i controlli necessari (3.23) e giustificazione per l'inclusione o l'esclusione dei controlli

Nota 1 alla voce: Le organizzazioni potrebbero non richiedere tutti i controlli elencati nell'allegato A o potrebbero addirittura superare l'elenco dell'allegato A con controlli aggiuntivi stabiliti dall'organizzazione stessa.

Nota 2 alla voce: Tutti i rischi identificati devono essere documentati dall'organizzazione secondo i requisiti del presente documento. Tutti i rischi identificati e le misure di gestione del rischio (controlli) adottate per affrontarli devono essere riportati nella dichiarazione di applicabilità.

4 Contesto dell'organizzazione

4.1 Comprendere l'organizzazione e il suo contesto

L'organizzazione deve determinare le questioni esterne e interne pertinenti al suo scopo e che influenzano la sua capacità di raggiungere i risultati attesi dal suo sistema di gestione dell'IA.

L'organizzazione deve determinare se il cambiamento climatico è un problema rilevante.

L'organizzazione deve considerare lo scopo previsto dei sistemi di IA sviluppati, forniti o utilizzati dall'organizzazione stessa e determinare i propri ruoli rispetto a tali sistemi.

NOTA 1 Per comprendere l'organizzazione e il suo contesto, può essere utile per l'organizzazione determinare il proprio ruolo rispetto al sistema di intelligenza artificiale. Questi ruoli possono includere, a titolo esemplificativo ma non esaustivo, uno o più dei seguenti:

- Fornitori di intelligenza artificiale, compresi i fornitori di piattaforme di intelligenza artificiale, fornitori di prodotti o servizi di intelligenza artificiale;
- Produttori di IA, tra cui sviluppatori di IA, progettisti di IA, operatori di IA, collaudatori e valutatori di IA, implementatori di IA, professionisti del fattore umano dell'IA, esperti di settore, valutatori dell'impatto dell'IA, responsabili degli appalti, professionisti della governance e della supervisione dell'IA;
- Clienti AI, compresi gli utenti AI;
- Partner di intelligenza artificiale, inclusi integratori di sistemi di intelligenza artificiale e fornitori di dati;
- Soggetti AI, compresi gli interessati e altri soggetti;
- le autorità competenti, compresi i decisori politici e gli enti regolatori.

Una descrizione dettagliata di questi ruoli è fornita da ISO/IEC 22989. Inoltre, i tipi di ruoli e la loro relazione con il ciclo di vita del sistema di intelligenza artificiale sono descritti anche nel framework di gestione del rischio di intelligenza artificiale del NIST.[29] I ruoli dell'organizzazione possono determinare l'applicabilità e l'estensione dell'applicabilità dei requisiti e dei controlli in questo documento.

NOTA 2 Le problematiche esterne e interne da affrontare ai sensi della presente clausola possono variare in base ai ruoli e alla giurisdizione dell'organizzazione e al loro impatto sulla sua capacità di raggiungere i risultati previsti dal proprio sistema di gestione dell'IA. Tra queste, a titolo esemplificativo ma non esaustivo:

a) considerazioni legate al contesto esterno quali:

- 1) requisiti legali applicabili, compresi gli usi vietati dell'IA;
- 2) politiche, linee guida e decisioni degli enti regolatori che hanno un impatto sull'interpretazione o sull'applicazione dei requisiti legali nello sviluppo e nell'uso dei sistemi di intelligenza artificiale;

1) In fase di preparazione. Fase al momento della pubblicazione della norma ISO/IEC DIS 5259-1:2023.

ISO/IEC 42001:2023(E)

- 3) incentivi o conseguenze associati allo scopo previsto e all'uso dei sistemi di intelligenza artificiale;
- 4) cultura, tradizioni, valori, norme ed etica rispetto allo sviluppo e all'uso dell'IA;
- 5) panorama competitivo e tendenze per nuovi prodotti e servizi che utilizzano sistemi di intelligenza artificiale;

b) considerazioni legate al contesto interno quali:

- 1) contesto organizzativo, governance, obiettivi (vedere 6.2), politiche e procedure;
- 2) obblighi contrattuali;
- 3) scopo previsto del sistema di intelligenza artificiale da sviluppare o utilizzare.

NOTA 3 La determinazione dei ruoli può essere basata su obblighi relativi alle categorie di dati trattati dall'organizzazione (ad esempio, responsabile del trattamento dei dati personali (PII) o titolare del trattamento dei dati personali (PII) in caso di trattamento dei dati personali). Si veda la norma ISO/IEC 29100 per i dati personali (PII) e i ruoli correlati. I ruoli possono anche essere definiti da requisiti legali specifici per i sistemi di intelligenza artificiale.

4.2 Comprendere le esigenze e le aspettative delle parti interessate

L'organizzazione deve determinare:

- le parti interessate rilevanti per il sistema di gestione dell'IA;
- le esigenze pertinenti di queste parti interessate;
- quali di questi requisiti saranno affrontati tramite il sistema di gestione dell'IA.

NOTA Le parti interessate possono avere esigenze legate ai cambiamenti climatici.

4.3 Determinazione dell'ambito del sistema di gestione dell'IA

L'organizzazione deve determinare i limiti e l'applicabilità del sistema di gestione dell'IA per stabilirne l'ambito.

Nel determinare questo ambito, l'organizzazione deve considerare:

- le questioni esterne ed interne di cui al [punto 4.1](#); ____
- i requisiti di cui al [punto 4.2](#). ____

L'ambito deve essere disponibile come informazione documentata.

L'ambito del sistema di gestione dell'IA determinerà le attività dell'organizzazione rispetto ai requisiti del presente documento sul sistema di gestione dell'IA, leadership, pianificazione, supporto, funzionamento, prestazioni, valutazione, miglioramento, controlli e obiettivi.

4.4 Sistema di gestione dell'intelligenza artificiale

L'organizzazione deve stabilire, implementare, mantenere, migliorare continuamente e documentare un sistema di gestione dell'IA, compresi i processi necessari e le relative interazioni, in conformità con i requisiti del presente documento.

5. Leadership

5.1 Leadership e impegno

Il top management dovrà dimostrare leadership e impegno nei confronti del sistema di gestione dell'IA attraverso:

- garantire che la politica sull'IA (vedere [5.2](#)) e gli obiettivi sull'IA (vedere [6.2](#)) siano stabiliti e siano compatibili con l'orientamento strategico dell'organizzazione;
- garantire l'integrazione dei requisiti del sistema di gestione dell'IA nell'organizzazione processi aziendali;
- garantire la disponibilità delle risorse necessarie per il sistema di gestione dell'IA;
- comunicare l'importanza di una gestione efficace dell'IA e di conformarsi ai requisiti del sistema di gestione dell'IA;
- garantire che il sistema di gestione dell'IA raggiunga i risultati previsti;
- indirizzare e supportare le persone che contribuiscono all'efficacia del sistema di gestione dell'IA;
- promuovere il miglioramento continuo;
- supportare altri ruoli rilevanti per dimostrare la loro leadership in quanto si applica alle loro aree di responsabilità.

NOTA 1 Il riferimento al termine "attività" nel presente documento può essere interpretato in senso lato, indicando quelle attività che sono fondamentali per gli scopi dell'esistenza dell'organizzazione.

NOTA 2 Stabilire, incoraggiare e modellare una cultura aziendale volta ad adottare un approccio responsabile all'utilizzo, allo sviluppo e alla gestione dei sistemi di IA può rappresentare un'importante dimostrazione di impegno e leadership da parte del top management. Garantire la consapevolezza e il rispetto di tale approccio responsabile, supportando il sistema di gestione dell'IA attraverso la leadership, può contribuire al successo del sistema di gestione dell'IA.

5.2 Politica di intelligenza artificiale

L'alta dirigenza deve stabilire una politica di intelligenza artificiale che:

- a) è appropriato allo scopo dell'organizzazione;
- b) fornisce un quadro per definire gli obiettivi dell'IA (vedere [6.2](#));
- c) include l'impegno a soddisfare i requisiti applicabili;
- d) include l'impegno al miglioramento continuo del sistema di gestione dell'IA.

La politica sull'intelligenza artificiale deve:

- essere disponibili come informazioni documentate;
- fare riferimento, se pertinente, ad altre politiche organizzative;
- essere comunicate all'interno dell'organizzazione;
- essere a disposizione delle parti interessate, ove opportuno.

Gli obiettivi di controllo e i controlli per stabilire una politica di IA sono forniti nella sezione A.2 della [Tabella A.1](#).
Le linee guida per l'implementazione di questi controlli sono fornite in [B.2](#).

NOTA Le considerazioni per le organizzazioni durante lo sviluppo di policy di intelligenza artificiale sono fornite nella norma ISO/IEC 38507.

ISO/IEC 42001:2023(E)

5.3 Ruoli, responsabilità e autorità

L'alta direzione deve garantire che le responsabilità e le autorità per i ruoli pertinenti siano assegnate e comunicate all'interno dell'organizzazione.

L'alta direzione deve assegnare la responsabilità e l'autorità per:

- a) garantire che il sistema di gestione dell'IA sia conforme ai requisiti del presente documento;
- b) comunicare al top management le prestazioni del sistema di gestione dell'IA.

NOTA Un controllo per definire e assegnare ruoli e responsabilità è fornito nella [Tabella A.1, punto A.3.2.](#)
Le linee guida per l'implementazione di questo controllo sono fornite in [B.3.2.](#)

6 Pianificazione

6.1 Azioni per affrontare rischi e opportunità

6.1.1 Generale

Nella pianificazione del sistema di gestione dell'IA, l'organizzazione deve considerare le problematiche di cui al [punto 4.1](#) e i requisiti di cui al [punto 4.2](#) e determinare i rischi e le opportunità che devono essere affrontati per:

- garantire che il sistema di gestione dell'IA possa raggiungere i risultati attesi;
- prevenire o ridurre gli effetti indesiderati;
- raggiungere un miglioramento continuo.

L'organizzazione deve stabilire e mantenere criteri di rischio IA che supportino:

- distinguere i rischi accettabili da quelli non accettabili;
- eseguire valutazioni del rischio dell'IA;
- condurre un trattamento del rischio di IA;
- valutazione dell'impatto del rischio dell'IA.

NOTA 1 Le considerazioni per determinare la quantità e il tipo di rischio che un'organizzazione è disposta a perseguire o mantenere sono fornite nelle norme ISO/IEC 38507 e ISO/IEC 23894.

L'organizzazione deve determinare i rischi e le opportunità in base a:

- il dominio e il contesto applicativo di un sistema di intelligenza artificiale;
- l'uso previsto;
- il contesto esterno ed interno descritto in [4.1.](#)

NOTA 2 Più di un sistema di IA può essere considerato nell'ambito del sistema di gestione dell'IA. In questo caso, la determinazione delle opportunità e degli utilizzi viene eseguita per ciascun sistema di IA o gruppi di sistemi di IA.

L'organizzazione deve pianificare:

- a) azioni per affrontare questi rischi e opportunità;
- b) come:
 - 1) integrare e implementare le azioni nei processi del sistema di gestione dell'IA;
 - 2) valutare l'efficacia di queste azioni.

L'organizzazione deve conservare informazioni documentate sulle azioni intraprese per identificare e affrontare i rischi e le opportunità dell'IA.

NOTA 3 La norma ISO/IEC 23894 fornisce indicazioni su come implementare la gestione del rischio per le organizzazioni che sviluppano, forniscono o utilizzano prodotti, sistemi e servizi di intelligenza artificiale.

NOTA 4 Il contesto dell'organizzazione e le sue attività possono avere un impatto sulle attività di gestione del rischio dell'organizzazione.

NOTA 5 Il modo di definire il rischio e quindi di concepire la gestione del rischio può variare a seconda dei settori e delle industrie. La definizione di rischio di cui al [punto 3.7](#) consente una visione ampia del rischio adattabile a qualsiasi settore, come quelli menzionati nell'Allegato D. In ogni caso, è compito dell'organizzazione, nell'ambito della valutazione del rischio, adottare innanzitutto una visione del rischio adattata al proprio contesto. Ciò può includere l'approccio al rischio attraverso le definizioni utilizzate nei settori in cui il sistema di IA è sviluppato e utilizzato, come la definizione contenuta nella Guida ISO/IEC 51.

6.1.2 Valutazione del rischio dell'IA

L'organizzazione deve definire e stabilire un processo di valutazione del rischio di IA che:

- a) è informato e allineato con la politica sull'IA (vedere [5.2](#)) e gli obiettivi dell'IA (vedere [6.2](#));

NOTA Quando si valutano le conseguenze come parte di [6.1.2 d\) 1](#), l'organizzazione può utilizzare una valutazione dell'impatto del sistema di intelligenza artificiale come indicato in [6.1.4](#).

- b) è progettato in modo tale che le ripetute valutazioni del rischio di IA possano produrre risultati coerenti, validi e comparabili risultati;

- c) identifica i rischi che favoriscono o impediscono il raggiungimento dei suoi obiettivi di IA;

- d) analizza i rischi dell'IA per:

- 1) valutare le potenziali conseguenze per l'organizzazione, gli individui e le società che potrebbero risultare se i rischi identificati dovessero materializzarsi;
- 2) valutare, ove applicabile, la probabilità realistica dei rischi identificati;
- 3) determinare i livelli di rischio;

- e) valuta i rischi dell'IA per:

- 1) confrontare i risultati dell'analisi del rischio con i criteri di rischio (vedere [6.1.1](#));
- 2) stabilire le priorità dei rischi valutati per il trattamento del rischio.

L'organizzazione deve conservare informazioni documentate sul processo di valutazione del rischio dell'IA.

6.1.3 Trattamento del rischio di IA

Tenendo conto dei risultati della valutazione del rischio, l'organizzazione deve definire un processo di trattamento del rischio di IA per:

- a) selezionare le opzioni appropriate per il trattamento del rischio di IA;

- b) determinare tutti i controlli necessari per attuare le opzioni di trattamento del rischio di IA scelte e confrontare i controlli con quelli nell'allegato A per verificare che non siano stati omessi controlli necessari;

NOTA 1 L'allegato A fornisce controlli di riferimento per soddisfare gli obiettivi organizzativi e affrontare i rischi correlati alla progettazione e all'uso dei sistemi di intelligenza artificiale.

- c) considerare i controlli dell'Allegato A che sono rilevanti per l'attuazione del trattamento del rischio di IA opzioni;

- d) identificare se sono necessari controlli aggiuntivi oltre a quelli indicati nell'allegato A per attuare tutti i rischi opzioni di trattamento;

ISO/IEC 42001:2023(E)

e) considerare le linee guida [dell'allegato B](#) per l'attuazione dei controlli determinati in b) e c);

NOTA 2 Gli obiettivi di controllo sono implicitamente inclusi nei controlli scelti. L'organizzazione può selezionare un insieme appropriato di obiettivi di controllo e controlli dall'Allegato A. I controlli [dell'Allegato A](#) non sono esaustivi e potrebbero essere necessari ulteriori obiettivi di controllo e controlli. Se sono necessari controlli diversi o aggiuntivi rispetto a quelli indicati [nell'Allegato A](#), l'organizzazione può progettare tali controlli o ricavarli da fonti esistenti. La gestione del rischio di IA può essere integrata in altri sistemi di gestione, se applicabile.

f) produrre una dichiarazione di applicabilità che contenga i controlli necessari [vedi b), c) e d)] e fornisca una giustificazione per l'inclusione e l'esclusione dei controlli. La giustificazione per l'esclusione può includere i casi in cui i controlli non sono ritenuti necessari dalla valutazione del rischio e non sono richiesti da (o sono soggetti a eccezioni ai sensi di) requisiti esterni applicabili.

NOTA 3 L'organizzazione può fornire giustificazioni documentate per l'esclusione di qualsiasi obiettivo di controllo in generale o per specifici sistemi di IA, siano essi elencati nell'allegato A o stabiliti dall'organizzazione stessa. _____

g) formulare un piano di trattamento del rischio di IA.

L'organizzazione deve ottenere l'approvazione della direzione designata per il piano di trattamento del rischio di IA e per l'accettazione dei rischi residui di IA. I controlli necessari devono essere:

- allineati agli obiettivi del [punto 6.2](#); _____
- disponibili come informazioni documentate;
- comunicate all'interno dell'organizzazione;
- a disposizione delle parti interessate, ove opportuno.

L'organizzazione deve conservare informazioni documentate sul processo di trattamento del rischio di IA.

6.1.4 Valutazione dell'impatto del sistema di intelligenza artificiale

L'organizzazione deve definire un processo per valutare le potenziali conseguenze per gli individui o gruppi di individui, o entrambi, e per le società che possono derivare dallo sviluppo, dalla fornitura o dall'utilizzo di sistemi di intelligenza artificiale.

La valutazione dell'impatto del sistema di intelligenza artificiale deve determinare le potenziali conseguenze che l'implementazione, l'uso previsto e il prevedibile uso improprio di un sistema di intelligenza artificiale possono avere sugli individui o sui gruppi di individui, o su entrambi, e sulle società.

La valutazione dell'impatto del sistema di IA terrà conto del contesto tecnico e sociale specifico in cui il sistema di IA viene implementato e delle giurisdizioni applicabili.

Il risultato della valutazione d'impatto del sistema di IA deve essere documentato. Ove opportuno, il risultato della valutazione d'impatto del sistema può essere reso disponibile alle parti interessate, come definito dall'organizzazione.

L'organizzazione deve considerare i risultati della valutazione d'impatto del sistema di IA nella valutazione del rischio (vedere [6.1.2](#)). Il punto A.5 della [Tabella A.1](#) fornisce i controlli per la valutazione dell'impatto dei sistemi di IA.

NOTA In alcuni contesti (ad esempio sistemi di intelligenza artificiale critici per la sicurezza o la privacy), l'organizzazione può richiedere che vengano eseguite valutazioni dell'impatto del sistema di intelligenza artificiale specifiche per disciplina (ad esempio impatto sulla sicurezza, sulla privacy o sulla protezione) come parte delle attività complessive di gestione del rischio di un'organizzazione.

6.2 Obiettivi dell'IA e pianificazione per raggiungerli

L'organizzazione deve stabilire obiettivi di IA a livello di funzioni e livelli pertinenti.

Gli obiettivi dell'IA devono:

- a) essere coerenti con la politica sull'IA (vedere [5.2](#)); _____

- b) essere misurabili (se praticabile);
- c) tenere conto dei requisiti applicabili;
- d) essere monitorati;
- e) essere comunicati;
- f) essere aggiornato se del caso;
- g) essere disponibili come informazioni documentate.

Quando si pianifica come raggiungere i propri obiettivi di intelligenza artificiale, l'organizzazione deve determinare:

- cosa verrà fatto;
- quali risorse saranno necessarie;
- chi sarà responsabile;
- quando sarà completato;
- come verranno valutati i risultati.

NOTA Un elenco non esaustivo di obiettivi di IA relativi alla gestione del rischio è fornito nell'Allegato C. Gli obiettivi di controllo e i controlli per l'identificazione di obiettivi per lo sviluppo e l'utilizzo responsabili dei sistemi di IA, nonché le misure per il loro raggiungimento, sono riportati nei paragrafi A.6.1 e A.9.3 della [Tabella A.1](#). Le linee guida per l'implementazione di questi controlli sono riportate nei [paragrafi B.6.1](#) e [B.9.3](#).

6.3 Pianificazione dei cambiamenti

Quando l'organizzazione determina la necessità di apportare modifiche al sistema di gestione dell'IA, tali modifiche devono essere eseguite in modo pianificato.

7 Supporto

7.1 Risorse

L'organizzazione deve determinare e fornire le risorse necessarie per l'istituzione, l'implementazione, la manutenzione e il miglioramento continuo del sistema di gestione dell'IA.

NOTA Gli obiettivi di controllo e i controlli per le risorse di IA sono forniti nella Sezione A.4 della [Tabella A.1](#). Le linee guida per l'implementazione di questi controlli sono fornite nella [Clausola B.4](#).

7.2 Competenza

L'organizzazione deve:

- determinare la competenza necessaria della/e persona/e che svolgono un lavoro sotto il suo controllo che influisce sulla sua IA prestazione;
- garantire che tali persone siano competenti sulla base di un'adeguata istruzione, formazione o esperienza;
- ove applicabile, adottare misure per acquisire le competenze necessarie e valutarne l'efficacia delle azioni intraprese.

Devono essere disponibili informazioni documentate appropriate come prova di competenza.

NOTA 1 Le linee guida per l'implementazione delle risorse umane, compresa la considerazione delle competenze necessarie, sono fornite in [B.4.6](#).

ISO/IEC 42001:2023(E)

NOTA 2 Le azioni applicabili possono includere, ad esempio: la fornitura di formazione, il tutoraggio o la riassegnazione di persone attualmente impiegate; oppure l'assunzione o la stipula di contratti con persone competenti.

7.3 Consapevolezza

Le persone che svolgono lavori sotto il controllo dell'organizzazione devono essere consapevoli di quanto segue:

- la politica sull'IA (vedere [5.2](#));
- il loro contributo all'efficacia del sistema di gestione dell'IA, compresi i benefici di prestazioni dell'intelligenza artificiale migliorate;
- le implicazioni della mancata conformità ai requisiti del sistema di gestione dell'IA.

7.4 Comunicazione

L'organizzazione deve determinare le comunicazioni interne ed esterne rilevanti per il sistema di gestione dell'IA, tra cui:

- cosa comunicherà;
- quando comunicare;
- con cui comunicare;
- come comunicare.

7.5 Informazioni documentate

7.5.1 Generale

Il sistema di gestione dell'IA dell'organizzazione deve includere:

- a) le informazioni documentate richieste dal presente documento;
- b) informazioni documentate che l'organizzazione ritiene necessarie per l'efficacia del sistema di gestione dell'IA.

NOTA L'estensione delle informazioni documentate per un sistema di gestione dell'IA può variare da un'organizzazione all'altra a causa di:

- le dimensioni dell'organizzazione e il tipo di attività, processi, prodotti e servizi;
- la complessità dei processi e delle loro interazioni;
- la competenza delle persone.

7.5.2 Creazione e aggiornamento delle informazioni documentate

Durante la creazione e l'aggiornamento delle informazioni documentate, l'organizzazione deve garantire in modo appropriato:

- identificazione e descrizione (ad esempio un titolo, una data, un autore o un numero di riferimento);
- formato (ad esempio lingua, versione del software, grafica) e supporto (ad esempio cartaceo, elettronico);
- revisione e approvazione per verificarne l'idoneità e l'adeguatezza.

7.5.3 Controllo delle informazioni documentate

Le informazioni documentate richieste dal sistema di gestione dell'IA e dal presente documento devono essere controllate per garantire:

- a) è disponibile e adatto all'uso, dove e quando è necessario;
- b) è adeguatamente protetto (ad esempio dalla perdita di riservatezza, dall'uso improprio o dalla perdita di integrità).

Per il controllo delle informazioni documentate, l'organizzazione deve affrontare le seguenti attività, a seconda dei casi:

- distribuzione, accesso, recupero e utilizzo;
- conservazione e conservazione, compresa la salvaguardia della leggibilità;
- controllo delle modifiche (ad esempio controllo delle versioni);
- conservazione e smaltimento.

Le informazioni documentate di origine esterna che l'organizzazione ritiene necessarie per la pianificazione e il funzionamento del sistema di gestione dell'IA devono essere identificate come appropriate e controllate.

NOTA L'accesso può implicare una decisione riguardante l'autorizzazione a visualizzare solo le informazioni documentate oppure l'autorizzazione e l'autorità per visualizzare e modificare le informazioni documentate.

8 Operazione

8.1 Pianificazione e controllo operativo

L'organizzazione deve pianificare, attuare e controllare i processi necessari per soddisfare i requisiti e attuare le azioni determinate nella [Clausola 6](#), mediante: _____

- stabilire criteri per i processi;
- attuare il controllo dei processi secondo i criteri.

L'organizzazione deve implementare i controlli determinati in base al [punto 6.1.3](#) che sono correlati al funzionamento del sistema di gestione dell'IA (ad esempio controlli relativi allo sviluppo del sistema di IA e al ciclo di vita del suo utilizzo).

L'efficacia di questi controlli deve essere monitorata e, qualora i risultati attesi non vengano raggiunti, devono essere prese in considerazione azioni correttive. [L'Allegato A](#) elenca i [controlli di riferimento](#) e [l'Allegato B](#) fornisce le linee guida per l'implementazione degli stessi.

Le informazioni documentate devono essere disponibili nella misura necessaria per avere la certezza che i processi siano stati eseguiti come pianificato.

L'organizzazione deve controllare le modifiche pianificate e analizzare le conseguenze delle modifiche indesiderate, adottando misure per mitigare eventuali effetti negativi, se necessario.

L'organizzazione deve garantire che i processi, i prodotti o i servizi forniti esternamente e rilevanti per il sistema di gestione dell'IA siano controllati.

8.2 Valutazione del rischio dell'IA

L'organizzazione deve eseguire valutazioni del rischio di IA in conformità al [punto 6.1.2](#) a [intervalli](#) pianificati o quando vengono proposti o si verificano cambiamenti significativi.

L'organizzazione deve conservare informazioni documentate sui risultati di tutte le valutazioni del rischio di IA.

8.3 Trattamento del rischio di IA

L'organizzazione deve implementare il piano di trattamento del rischio di IA secondo quanto previsto al [punto 6.1.3](#) e verificarne l'efficacia.

Quando le valutazioni dei rischi individuano nuovi rischi che richiedono un trattamento, per tali rischi deve essere eseguito un processo di [trattamento](#) dei rischi in conformità al [punto 6.1.3](#).

Quando le opzioni di trattamento del rischio definite dal piano di trattamento del rischio non sono efficaci, tali opzioni di trattamento devono essere riviste e convalidate nuovamente seguendo il processo di trattamento del rischio secondo quanto previsto al [punto 6.1.3](#) e il piano di trattamento del rischio deve essere aggiornato.

L'organizzazione deve conservare informazioni documentate sui risultati di tutti i trattamenti del rischio di IA.

8.4 Valutazione dell'impatto del sistema di intelligenza artificiale

L'organizzazione deve eseguire valutazioni dell'impatto del sistema di IA secondo quanto previsto al [punto 6.1.4](#) a intervalli pianificati o quando si prevede che si verifichino modifiche significative.

L'organizzazione deve conservare informazioni documentate sui risultati di tutte le valutazioni di impatto del sistema di intelligenza artificiale.

9 Valutazione delle prestazioni

9.1 Monitoraggio, misurazione, analisi e valutazione

L'organizzazione deve determinare:

- cosa deve essere monitorato e misurato;
- i metodi di monitoraggio, misurazione, analisi e valutazione, ove applicabili, per garantire la validità risultati;
- quando devono essere effettuati il monitoraggio e la misurazione;
- quando i risultati del monitoraggio e della misurazione devono essere analizzati e valutati.

A titolo di prova dei risultati dovranno essere disponibili informazioni documentate.

L'organizzazione deve valutare le prestazioni e l'efficacia del sistema di gestione dell'IA.

9.2 Revisione interna

9.2.1 Generale

L'organizzazione deve condurre audit interni a intervalli pianificati per fornire informazioni su se il sistema di gestione dell'IA:

a) è conforme a:

- 1) i requisiti propri dell'organizzazione per il proprio sistema di gestione dell'intelligenza artificiale;
- 2) i requisiti del presente documento;

b) è implementato e mantenuto in modo efficace.

9.2.2 Programma di audit interno

L'organizzazione deve pianificare, stabilire, attuare e mantenere uno o più programmi di audit, inclusa la frequenza, i metodi, le responsabilità, i requisiti di pianificazione e la rendicontazione.

Quando si stabilisce il/i programma/i di audit interno/i, l'organizzazione deve considerare l'importanza dei processi interessati e i risultati degli audit precedenti.

L'organizzazione deve:

- a) definire gli obiettivi di audit, i criteri e l'ambito di applicazione di ciascun audit;
- b) selezionare i revisori e condurre gli audit per garantire l'obiettività e l'imparzialità del processo di audit;
- c) garantire che i risultati degli audit siano comunicati ai responsabili competenti.

Devono essere disponibili informazioni documentate come prova dell'attuazione del/i programma/i di audit e dei risultati dell'audit.

9.3 Revisione della direzione

9.3.1 Generale

L'alta direzione è tenuta a rivedere il sistema di gestione dell'IA dell'organizzazione, a intervalli pianificati, per garantirne la continua idoneità, adeguatezza ed efficacia.

9.3.2 Input di revisione della direzione

La revisione della direzione deve includere:

- a) lo stato delle azioni intraprese a seguito delle precedenti revisioni della direzione;
- b) cambiamenti nelle questioni esterne e interne rilevanti per il sistema di gestione dell'IA;
- c) cambiamenti nelle esigenze e nelle aspettative delle parti interessate che sono rilevanti per la gestione dell'IA sistema;
- d) informazioni sulle prestazioni del sistema di gestione dell'IA, comprese le tendenze relative a:
 - 1) non conformità e azioni correttive;
 - 2) risultati del monitoraggio e della misurazione;
 - 3) risultati di audit;
- e) opportunità di miglioramento continuo.

9.3.3 Risultati della revisione della direzione

I risultati della revisione della direzione dovranno includere decisioni relative alle opportunità di miglioramento continuo e a qualsiasi necessità di modifiche al sistema di gestione dell'IA.

Devono essere disponibili informazioni documentate come prova dei risultati delle revisioni della direzione.

10 Miglioramento

10.1 Miglioramento continuo

L'organizzazione deve migliorare continuamente l'idoneità, l'adeguatezza e l'efficacia del sistema di gestione dell'IA.

ISO/IEC 42001:2023(E)

10.2 Non conformità e azioni correttive

Quando si verifica una non conformità, l'organizzazione deve:

a) reagire alla non conformità e, se del caso:

- 1) adottare misure per controllarlo e correggerlo;
- 2) affrontare le conseguenze;

b) valutare la necessità di azioni volte ad eliminare la/le causa/e della non conformità, affinché questa non si ripeta o non si verifichi altrove, mediante:

- 1) revisione della non conformità;
- 2) determinare le cause della non conformità;
- 3) determinare se sussistono o possono potenzialmente verificarsi non conformità simili;

c) attuare qualsiasi azione necessaria;

d) verificare l'efficacia di ogni azione correttiva intrapresa;

e) apportare modifiche al sistema di gestione dell'IA, se necessario.

Le azioni correttive devono essere appropriate agli effetti delle non conformità riscontrate.

Le informazioni documentate devono essere disponibili come prova di:

- la natura delle non conformità e le eventuali azioni successive intraprese;
- i risultati di eventuali azioni correttive.

Allegato A
(normativo)

Obiettivi e controlli di controllo di riferimento

A.1 Generale

I controlli dettagliati nella [Tabella A.1](#) forniscono all'organizzazione un riferimento per il raggiungimento degli obiettivi organizzativi e la gestione dei rischi relativi alla progettazione e al funzionamento dei sistemi di IA. Non tutti gli obiettivi e i controlli di controllo elencati nella [Tabella A.1](#) sono obbligatori e l'organizzazione può progettare e implementare i propri controlli (vedere [6.1.3](#)).

L'[allegato B](#) fornisce indicazioni sull'implementazione di tutti i controlli elencati nella [Tabella A.1](#).

Tabella A.1 — Obiettivi di controllo e controlli

A.2 Politiche relative all'IA		
Obiettivo: fornire indicazioni e supporto gestionali per i sistemi di intelligenza artificiale in base alle esigenze aziendali.		
	Argomento	Controllare
A.2.2	Politica sull'intelligenza artificiale	L'organizzazione deve documentare una politica per lo sviluppo o l'uso di sistemi di intelligenza artificiale.
A.2.3	Allineamento con altre politiche organizzative	L'organizzazione deve determinare in che modo altre politiche possano essere influenzate o applicate agli obiettivi dell'organizzazione rispetto ai sistemi di intelligenza artificiale.
A.2.4	Revisione della politica sull'intelligenza artificiale	La politica sull'IA sarà rivista a intervalli pianificati o ulteriormente, se necessario, per garantirne costantemente l'idoneità, l'adeguatezza e l'efficacia.
A.3 Organizzazione interna		
Obiettivo: stabilire la responsabilità all'interno dell'organizzazione per sostenere il suo approccio responsabile per l'implementazione, il funzionamento e la gestione dei sistemi di intelligenza artificiale.		
	Argomento	Controllare
A.3.2	Ruoli e responsabilità dell'IA	I ruoli e le responsabilità dell'IA devono essere definiti e assegnati in base alle esigenze dell'organizzazione.
A.3.3	Segnalazione di preoccupazioni	L'organizzazione deve definire e attuare una procedura per segnalare dubbi sul ruolo dell'organizzazione rispetto a un sistema di intelligenza artificiale durante tutto il suo ciclo di vita.
A.4 Risorse per i sistemi di intelligenza artificiale		
Obiettivo: garantire che l'organizzazione tenga conto delle risorse (inclusi i componenti e gli asset del sistema di intelligenza artificiale) del sistema di intelligenza artificiale per comprendere e affrontare appieno i rischi e gli impatti.		
	Argomento	Controllare
A.4.2	Documentazione delle risorse	L'organizzazione deve identificare e documentare le risorse pertinenti richieste per le attività nelle fasi del ciclo di vita del sistema di intelligenza artificiale e altre attività correlate all'intelligenza artificiale rilevanti per l'organizzazione.
A.4.3	Risorse di dati	Nell'ambito dell'identificazione delle risorse, l'organizzazione dovrà documentare le informazioni sulle risorse dati utilizzate per il sistema di intelligenza artificiale.
A.4.4	Risorse di utensili	Come parte dell'identificazione delle risorse, l'organizzazione deve documentare le informazioni sulle risorse di strumenti utilizzate per il sistema di intelligenza artificiale.

ISO/IEC 42001:2023(E)

Tabella A.1 (continua)

A.4.5	Risorse di sistema e di elaborazione	Come parte dell'identificazione delle risorse, l'organizzazione deve documentare le informazioni sul sistema e sulle risorse di elaborazione utilizzate per il sistema di intelligenza artificiale.
A.4.6	Risorse umane	Nell'ambito dell'identificazione delle risorse, l'organizzazione deve documentare le informazioni sulle risorse umane e sulle loro competenze utilizzate per lo sviluppo, l'implementazione, il funzionamento, la gestione del cambiamento, la manutenzione, il trasferimento e la dismissione, nonché la verifica e l'integrazione del sistema di intelligenza artificiale.
A.5 Valutazione degli impatti dei sistemi di intelligenza artificiale		
Obiettivo: valutare l'impatto del sistema di intelligenza artificiale sugli individui o sui gruppi di individui, o su entrambi, e sulle società interessate dal sistema di intelligenza artificiale durante tutto il suo ciclo di vita.		
	Argomento	Controllare
A.5.2	Processo di valutazione dell'impatto del sistema di intelligenza artificiale	L'organizzazione deve stabilire un processo per valutare le potenziali conseguenze per gli individui o gruppi di individui, o entrambi, e per le società che possono derivare dal sistema di intelligenza artificiale durante il suo intero ciclo di vita.
A.5.3	Documentazione delle valutazioni di impatto del sistema di intelligenza artificiale	L'organizzazione deve documentare i risultati delle valutazioni di impatto del sistema di intelligenza artificiale e conservarli per un periodo di tempo definito.
A.5.4	Valutazione dell'impatto del sistema di intelligenza artificiale su individui o gruppi di individui	L'organizzazione deve valutare e documentare i potenziali impatti dei sistemi di intelligenza artificiale sugli individui o sui gruppi di individui durante l'intero ciclo di vita del sistema.
A.5.5	Valutazione dell'impatto sociale dei sistemi di intelligenza artificiale	L'organizzazione dovrà valutare e documentare i potenziali impatti sociali dei propri sistemi di intelligenza artificiale durante tutto il loro ciclo di vita.
A.6 Ciclo di vita del sistema di intelligenza artificiale		
A.6.1 Linee guida di gestione per lo sviluppo del sistema di intelligenza artificiale		
Obiettivo: garantire che l'organizzazione identifichi e documenti gli obiettivi e implementi processi per la progettazione e lo sviluppo responsabili dei sistemi di intelligenza artificiale.		
	Argomento	Controllare
A.6.1.2	Obiettivi per lo sviluppo responsabile del sistema di intelligenza artificiale	L'organizzazione deve identificare e documentare gli obiettivi per orientare lo sviluppo responsabile dei sistemi di intelligenza artificiale, tenerne conto e integrare le misure per conseguirli nel ciclo di vita dello sviluppo.
A.6.1.3	Processi per la progettazione e lo sviluppo responsabile dei sistemi di intelligenza artificiale	L'organizzazione deve definire e documentare i processi specifici per la progettazione e lo sviluppo responsabili del sistema di intelligenza artificiale.
A.6.2 Ciclo di vita del sistema di intelligenza artificiale		
Obiettivo: definire i criteri e i requisiti per ogni fase del ciclo di vita del sistema di intelligenza artificiale.		
	Argomento	Controllare
A.6.2.2	Requisiti e specifiche del sistema AI	L'organizzazione deve specificare e documentare i requisiti per i nuovi sistemi di intelligenza artificiale o per i miglioramenti sostanziali dei sistemi esistenti.
A.6.2.3	Documentazione della progettazione del sistema di intelligenza artificiale	L'organizzazione deve documentare la progettazione e lo sviluppo del sistema di intelligenza artificiale basato su obiettivi organizzativi, requisiti documentati e criteri di specifica.
A.6.2.4	Verifica e convalida del sistema di intelligenza artificiale	L'organizzazione deve definire e documentare le misure di verifica e convalida del sistema di intelligenza artificiale e specificare i criteri per il loro utilizzo.
A.6.2.5	Implementazione del sistema di intelligenza artificiale	L'organizzazione deve documentare un piano di distribuzione e garantire che vengano soddisfatti i requisiti appropriati prima della distribuzione.

Tabella A.1 (continua)

A.6.2.6	Funzionamento e monitoraggio del sistema di intelligenza artificiale	L'organizzazione deve definire e documentare gli elementi necessari per il funzionamento continuo del sistema di intelligenza artificiale. Come minimo, ciò dovrebbe includere il monitoraggio del sistema e delle prestazioni, le riparazioni, gli aggiornamenti e il supporto.
A.6.2.7	Documentazione tecnica del sistema di intelligenza artificiale	L'organizzazione deve determinare quale documentazione tecnica del sistema di intelligenza artificiale. È necessaria la documentazione tecnica per ciascuna categoria rilevante di parti interessate, quali utenti, partner, autorità di vigilanza, e fornire loro la documentazione tecnica nella forma appropriata.
A.6.2.8	Registrazione degli eventi tramite il sistema AI	L'organizzazione deve determinare in quali fasi del ciclo di vita del sistema di intelligenza artificiale, la tenuta dei registri degli eventi dovrebbe essere abilitata, ma almeno quando il sistema di intelligenza artificiale è in uso.
A.7 Dati per i sistemi di intelligenza artificiale		
Obiettivo: garantire che l'organizzazione comprenda il ruolo e l'impatto dei dati nei sistemi di intelligenza artificiale nell'applicazione e nello sviluppo, nella fornitura o nell'uso dei sistemi di intelligenza artificiale durante il loro ciclo di vita.		
	Dati	Controllare
A.7.2	sull'argomento per lo sviluppo e il miglioramento del sistema di intelligenza artificiale	L'organizzazione deve definire, documentare e implementare processi di gestione dei dati correlati allo sviluppo di sistemi di intelligenza artificiale.
A.7.3	Acquisizione dei dati	L'organizzazione deve determinare e documentare i dettagli relativi all'acquisizione e alla selezione dei dati utilizzati nei sistemi di intelligenza artificiale.
A.7.4	Qualità dei dati per i sistemi di intelligenza artificiale	L'organizzazione deve definire e documentare i requisiti per la qualità dei dati e garantire che i dati utilizzati per sviluppare e gestire il sistema di intelligenza artificiale soddisfino tali requisiti.
A.7.5	Provenienza dei dati	L'organizzazione deve definire e documentare un processo per registrare la provenienza dei dati utilizzati nei suoi sistemi di intelligenza artificiale durante l'intero ciclo di vita dei dati e del sistema di intelligenza artificiale.
A.7.6	Preparazione dei dati	L'organizzazione deve definire e documentare i propri criteri per la selezione delle preparazioni dei dati e i metodi di preparazione dei dati da utilizzare.
A.8 Informazioni per le parti interessate ai sistemi di IA		
Obiettivo: garantire che le parti interessate dispongano delle informazioni necessarie per comprendere e valutare i rischi e i relativi impatti (sia positivi che negativi).		
	Argomento	Controllare
A.8.2	Documentazione e informazioni di sistema per gli utenti	L'organizzazione deve determinare e fornire le informazioni necessarie agli utenti del sistema di intelligenza artificiale.
A.8.3	Reporting esterno	L'organizzazione deve fornire alle parti interessate gli strumenti per segnalare gli impatti negativi del sistema di intelligenza artificiale.
A.8.4	Comunicazione degli incidenti	L'organizzazione deve determinare e documentare un piano per comunicare gli incidenti agli utenti del sistema di intelligenza artificiale.
A.8.5	Informazioni per le parti interessate	L'organizzazione deve determinare e documentare le proprie obbligazioni di comunicazione alle parti interessate di informazioni sul sistema di IA.
A.9 Utilizzo di sistemi di intelligenza artificiale		
Obiettivo: garantire che l'organizzazione utilizzi i sistemi di intelligenza artificiale in modo responsabile e conforme alle policy aziendali.		
		Controllare
A.9.2	Argomento Processi per l'uso responsabile dell'IA	L'organizzazione deve definire e documentare i processi per l'uso responsabile dei sistemi di IA.
A.9.3	Obiettivi per un uso responsabile dell'IA	L'organizzazione deve identificare e documentare gli obiettivi per guidare l'uso responsabile dei sistemi di IA.

ISO/IEC 42001:2023(E)

Tabella A.1 (continua)

A.9.4	Uso previsto del sistema di intelligenza artificiale	L'organizzazione deve garantire che il sistema di IA venga utilizzato secondo gli usi previsti e nella documentazione allegata.
A.10 Rapporti con terze parti e clienti		
Obiettivo: garantire che l'organizzazione comprenda le proprie responsabilità e continui a rispondere delle proprie azioni, e che i rischi siano opportunamente ripartiti quando terze parti sono coinvolte in qualsiasi fase del ciclo di vita del sistema di intelligenza artificiale.		
	Argomento	Controllare
A.10.2	Assegnazione delle responsabilità	L'organizzazione deve garantire che le responsabilità all'interno del ciclo di vita del proprio sistema di intelligenza artificiale siano suddivise tra l'organizzazione stessa, i suoi partner, fornitori, clienti e terze parti.
A.10.3	Fornitori	L'organizzazione deve stabilire un processo per garantire che l'utilizzo di servizi, prodotti o materiali forniti dai fornitori sia in linea con l'approccio dell'organizzazione allo sviluppo e all'uso responsabili dei sistemi di intelligenza artificiale.
A.10.4	Clienti	L'organizzazione deve garantire che il suo approccio responsabile allo sviluppo e all'uso dei sistemi di intelligenza artificiale tenga conto delle aspettative e delle esigenze dei propri clienti.

Allegato B (normativo)

Guida all'implementazione per i controlli dell'IA

B.1 Generale

Le linee guida per l'implementazione documentate in questo allegato si riferiscono ai controlli elencati nella [Tabella A.1](#). Forniscono informazioni a supporto dell'implementazione dei controlli elencati nella [Tabella A.1](#) e del raggiungimento dell'obiettivo di controllo, ma le organizzazioni non sono tenute a documentare o giustificare l'inclusione o l'esclusione delle linee guida per l'implementazione nella dichiarazione di applicabilità (vedere [6.1.3](#)).

Le linee guida per l'implementazione non sono sempre adatte o sufficienti in tutte le situazioni e non sempre soddisfano i requisiti di controllo specifici dell'organizzazione. L'organizzazione può estendere o modificare le linee guida per l'implementazione o definire la propria implementazione di un controllo in base ai propri requisiti specifici e alle esigenze di gestione del rischio.

Il presente allegato deve essere utilizzato come guida per la determinazione e l'implementazione dei controlli per il trattamento del rischio di IA nel sistema di gestione dell'IA definito nel presente documento. È possibile definire ulteriori controlli organizzativi e tecnici oltre a quelli inclusi nel presente allegato (vedere il trattamento del rischio di gestione del sistema di IA al [punto 6.1.3](#)). Il presente allegato può essere considerato un [punto di partenza](#) per lo sviluppo dell'implementazione di controlli specifici per ogni organizzazione.

B.2 Politiche relative all'IA

B.2.1 Obiettivo

Fornire direzione e supporto alla gestione dei sistemi di intelligenza artificiale in base alle esigenze aziendali.

B.2.2 Politica di intelligenza artificiale

Controllare

L'organizzazione dovrebbe documentare una politica per lo sviluppo o l'utilizzo di sistemi di intelligenza artificiale.

Guida all'implementazione

La politica sull'intelligenza artificiale dovrebbe basarsi su:

- strategia aziendale;
- valori e cultura organizzativa e quantità di rischio che l'organizzazione è disposta a perseguire o conservare;
- il livello di rischio rappresentato dai sistemi di intelligenza artificiale;
- requisiti legali, compresi i contratti;
- l'ambiente di rischio dell'organizzazione;
- impatto sulle parti interessate rilevanti (vedere [6.1.4](#)).

La politica sull'intelligenza artificiale dovrebbe includere (oltre ai requisiti del [punto 5.2](#)):

- principi che guidano tutte le attività dell'organizzazione relative all'IA;

ISO/IEC 42001:2023(E)

— processi per la gestione delle deviazioni e delle eccezioni alla politica.

La politica sull'intelligenza artificiale dovrebbe considerare aspetti specifici per argomento, ove necessario, per fornire ulteriori indicazioni o riferimenti incrociati ad altre politiche che trattano tali aspetti. Esempi di tali argomenti includono:

- Risorse e asset di intelligenza artificiale;
- Valutazioni di impatto del sistema di intelligenza artificiale (vedere [6.1.4](#));
- Sviluppo di sistemi di intelligenza artificiale.

Lo sviluppo, l'acquisto, il funzionamento e l'uso dei sistemi di intelligenza artificiale dovrebbero essere guidati da politiche adeguate.

B.2.3 Allineamento con altre politiche organizzative

Controllare

L'organizzazione dovrebbe determinare in che modo altre politiche possano essere influenzate o applicate agli obiettivi dell'organizzazione rispetto ai sistemi di intelligenza artificiale.

Guida all'implementazione

Molti ambiti si intersecano con l'IA, tra cui qualità, sicurezza, protezione e privacy. L'organizzazione dovrebbe valutare un'analisi approfondita per determinare se e dove le policy attuali possano necessariamente intersecarsi e aggiornarle se necessario, oppure includere disposizioni nella policy sull'IA.

Altre informazioni

Le politiche che l'organo di governo stabilisce per conto dell'organizzazione dovrebbero ispirare la politica sull'intelligenza artificiale. La norma ISO/IEC 38507 fornisce linee guida ai membri dell'organo di governo di un'organizzazione per abilitare e governare il sistema di intelligenza artificiale durante tutto il suo ciclo di vita.

B.2.4 Revisione della politica sull'IA

Controllare

La politica in materia di intelligenza artificiale dovrebbe essere rivista a intervalli pianificati o in aggiunta, quando necessario, per garantirne costantemente l'idoneità, l'adeguatezza e l'efficacia.

Guida all'implementazione

Un ruolo approvato dal management dovrebbe essere responsabile dello sviluppo, della revisione e della valutazione della politica di IA, o dei suoi componenti. La revisione dovrebbe includere la valutazione delle opportunità di miglioramento delle politiche e dell'approccio dell'organizzazione alla gestione dei sistemi di IA in risposta ai cambiamenti del contesto organizzativo, delle circostanze aziendali, delle condizioni legali o dell'ambiente tecnico.

La revisione della politica in materia di intelligenza artificiale dovrebbe tenere conto dei risultati delle revisioni della direzione.

B.3 Organizzazione interna

B.3.1 Obiettivo

Per stabilire la responsabilità all'interno dell'organizzazione affinché mantenga un approccio responsabile per l'implementazione, il funzionamento e la gestione dei sistemi di intelligenza artificiale.

B.3.2 Ruoli e responsabilità dell'IA

Controllare

I ruoli e le responsabilità dell'IA dovrebbero essere definiti e assegnati in base alle esigenze dell'organizzazione.

Guida all'implementazione

Definire ruoli e responsabilità è fondamentale per garantire la responsabilità all'interno dell'organizzazione per il proprio ruolo nel sistema di IA durante tutto il suo ciclo di vita. L'organizzazione dovrebbe considerare le policy, gli obiettivi e i rischi identificati in materia di IA nell'assegnazione di ruoli e responsabilità, al fine di garantire la copertura di tutte le aree rilevanti. L'organizzazione può stabilire le priorità per l'assegnazione di ruoli e responsabilità. Esempi di aree che possono richiedere ruoli e responsabilità definiti includono:

- gestione del rischio;
- Valutazioni di impatto del sistema di intelligenza artificiale;
- gestione delle risorse e degli asset;
- sicurezza;
- sicurezza;
- riservatezza;
- sviluppo;
- prestazione;
- supervisione umana;
- rapporti con i fornitori;
- dimostrare la propria capacità di soddisfare costantemente i requisiti legali;
- gestione della qualità dei dati (durante l'intero ciclo di vita).

Le responsabilità dei vari ruoli devono essere definite a un livello adeguato affinché gli individui possano svolgere i propri compiti.

B.3.3 Segnalazione di preoccupazioni

Controllare

L'organizzazione dovrebbe definire e attuare una procedura per segnalare dubbi sul ruolo dell'organizzazione rispetto a un sistema di intelligenza artificiale durante tutto il suo ciclo di vita.

Guida all'implementazione

Il meccanismo di segnalazione dovrebbe svolgere le seguenti funzioni:

- a) opzioni per la riservatezza o l'anonimato o entrambi;
- b) disponibili e promossi a persone impiegate e contrattuali;
- c) dotato di personale qualificato;
- d) prevede adeguati poteri di indagine e di risoluzione per i soggetti di cui alla lettera c);
- e) prevede meccanismi per segnalare e segnalare tempestivamente alla direzione i problemi;
- f) garantisce un'efficace protezione dalle ritorsioni sia per le persone coinvolte nella segnalazione che per quelle coinvolte nelle indagini (ad esempio consentendo che le segnalazioni siano presentate in forma anonima e confidenziale);
- g) fornisce relazioni secondo quanto previsto al [punto 4.4](#) e, se del caso, e); mantenendo la riservatezza e l'anonimato di cui al punto a), e rispettando le considerazioni generali sulla riservatezza aziendale;
- h) fornisce meccanismi di risposta entro un lasso di tempo adeguato.

ISO/IEC 42001:2023(E)

NOTA L'organizzazione può utilizzare i meccanismi di segnalazione esistenti come parte di questo processo.

Altre informazioni

Oltre alle linee guida sull'implementazione fornite in questa clausola, l'organizzazione dovrebbe prendere in considerazione anche la norma ISO 37002.

B.4 Risorse per i sistemi di intelligenza artificiale

B.4.1 Obiettivo

Per garantire che l'organizzazione tenga conto delle risorse (inclusi i componenti e gli asset del sistema di intelligenza artificiale) del sistema di intelligenza artificiale, al fine di comprendere e affrontare appieno i rischi e gli impatti.

B.4.2 Documentazione delle risorse

Controllare

L'organizzazione dovrebbe identificare e documentare le risorse rilevanti richieste per le attività in determinate fasi del ciclo di vita del sistema di intelligenza artificiale e altre attività correlate all'intelligenza artificiale rilevanti per l'organizzazione.

Guida all'implementazione

La documentazione delle risorse del sistema di IA è fondamentale per comprendere i rischi, nonché i potenziali impatti (positivi e negativi) del sistema di IA su individui o gruppi di individui, o entrambi, e sulla società. La documentazione di tali risorse (che può utilizzare, ad esempio, diagrammi di flusso dei dati o diagrammi dell'architettura di sistema) può essere utile per le valutazioni di impatto del sistema di IA (vedere [B.5](#)).

Le risorse possono includere, ma non sono limitate a:

- Componenti del sistema di intelligenza artificiale;
- risorse di dati, ovvero dati utilizzati in qualsiasi fase del ciclo di vita del sistema di intelligenza artificiale;
- risorse di strumenti (ad esempio algoritmi, modelli o strumenti di intelligenza artificiale);
- risorse di sistema e di elaborazione (ad esempio hardware per sviluppare ed eseguire modelli di intelligenza artificiale, archiviazione per dati e risorse di utensili);
- risorse umane, vale a dire persone dotate delle competenze necessarie (ad esempio per lo sviluppo, la vendita, la formazione, il funzionamento e la manutenzione del sistema di intelligenza artificiale) in relazione al ruolo dell'organizzazione durante l'intero ciclo di vita del sistema di intelligenza artificiale.

Le risorse possono essere fornite dall'organizzazione stessa, dai suoi clienti o da terze parti.

Altre informazioni

La documentazione delle risorse può anche aiutare a determinare se le risorse sono disponibili e, in caso contrario, l'organizzazione dovrebbe rivedere le specifiche di progettazione del sistema di intelligenza artificiale o i suoi requisiti di distribuzione.

B.4.3 Risorse di dati

Controllare

Nell'ambito dell'identificazione delle risorse, l'organizzazione dovrebbe documentare le informazioni sulle risorse di dati utilizzate per il sistema di intelligenza artificiale.

Guida all'implementazione

La documentazione sui dati dovrebbe includere, ma non limitarsi ai seguenti argomenti:

- la provenienza dei dati;
- la data dell'ultimo aggiornamento o modifica dei dati (ad esempio il tag data nei metadati);
- per l'apprendimento automatico, le categorie di dati (ad esempio dati di formazione, convalida, test e produzione);
- categorie di dati (ad esempio come definite in ISO/IEC 19944-1);
- procedimento per l'etichettatura dei dati;
- l'uso previsto dei dati;
- qualità dei dati (ad esempio come descritto nella serie ISO/IEC 52592);
- politiche applicabili di conservazione e smaltimento dei dati;
- problemi di distorsione noti o potenziali nei dati;
- preparazione dei dati.

B.4.4 Risorse di utensili**Controllare**

Come parte dell'identificazione delle risorse, l'organizzazione dovrebbe documentare le informazioni sulle risorse di strumenti utilizzate per il sistema di intelligenza artificiale.

Guida all'implementazione

Le risorse di strumentazione per un sistema di intelligenza artificiale e in particolare per l'apprendimento automatico possono includere, a titolo esemplificativo ma non esaustivo:

- tipi di algoritmi e modelli di apprendimento automatico;
- strumenti o processi di condizionamento dei dati;
- metodi di ottimizzazione;
- metodi di valutazione;
- strumenti di provisioning per le risorse;
- strumenti per facilitare lo sviluppo del modello;
- software e hardware per la progettazione, lo sviluppo e l'implementazione di sistemi di intelligenza artificiale.

Altre informazioni

La norma ISO/IEC 23053 fornisce indicazioni dettagliate sui tipi, metodi e approcci per varie risorse di strumenti per l'apprendimento automatico.

B.4.5 Risorse di sistema e di elaborazione**Controllare**

Come parte dell'identificazione delle risorse, l'organizzazione dovrebbe documentare le informazioni sul sistema e sulle risorse di elaborazione utilizzate per il sistema di intelligenza artificiale.

2) In fase di preparazione. Fase al momento della pubblicazione: ISO/IEC DIS 5259-1:2023, ISO/IEC DIS 5259-2:2023, ISO/IEC DIS 5259-3:2023, ISO/IEC DIS 5259-4:2023, ISO/IEC CD 5259-5:2023.

ISO/IEC 42001:2023(E)

Guida all'implementazione

Le informazioni sulle risorse di sistema e di elaborazione di un sistema di intelligenza artificiale possono includere, a titolo esemplificativo ma non esaustivo:

- requisiti di risorse del sistema di intelligenza artificiale (ad esempio per garantire che il sistema possa funzionare con risorse limitate dispositivi di risorse);
- dove si trovano il sistema e le risorse di elaborazione (ad esempio on-premise, cloud computing o edge informatica);
- risorse di elaborazione (incluse rete e storage);
- l'impatto dell'hardware utilizzato per eseguire i carichi di lavoro del sistema di intelligenza artificiale (ad esempio l'impatto sull'ambiente dovuto all'uso o alla produzione dell'hardware o al costo di utilizzo dell'hardware).

L'organizzazione dovrebbe considerare che per consentire il miglioramento continuo dei sistemi di IA potrebbero essere necessarie risorse diverse. Lo sviluppo, l'implementazione e il funzionamento del sistema possono avere esigenze e requisiti diversi.

NOTA La norma ISO/IEC 22989 descrive varie considerazioni sulle risorse di sistema.

B.4.6 Risorse umane

Controllare

Nell'ambito dell'identificazione delle risorse, l'organizzazione dovrebbe documentare le informazioni sulle risorse umane e sulle loro competenze utilizzate per lo sviluppo, l'implementazione, il funzionamento, la gestione del cambiamento, la manutenzione, il trasferimento e la dismissione, nonché la verifica e l'integrazione del sistema di intelligenza artificiale.

Guida all'implementazione

L'organizzazione dovrebbe considerare la necessità di competenze diversificate e includere le tipologie di ruoli necessarie per il sistema. Ad esempio, l'organizzazione può includere specifici gruppi demografici relativi ai set di dati utilizzati per addestrare modelli di apprendimento automatico, se la loro inclusione è una componente necessaria della progettazione del sistema. Le risorse umane necessarie possono includere, a titolo esemplificativo ma non esaustivo:

- scienziati dei dati;
- ruoli legati alla supervisione umana dei sistemi di intelligenza artificiale;
- esperti in argomenti di affidabilità quali sicurezza, protezione e privacy;
- Ricercatori e specialisti dell'intelligenza artificiale, nonché esperti del settore attinenti ai sistemi di intelligenza artificiale.

Nelle diverse fasi del ciclo di vita del sistema di intelligenza artificiale possono essere necessarie risorse diverse.

B.5 Valutazione degli impatti dei sistemi di intelligenza artificiale

B.5.1 Obiettivo

Per valutare l'impatto del sistema di intelligenza artificiale sugli individui o sui gruppi di individui, o su entrambi, e sulle società interessate dal sistema di intelligenza artificiale durante tutto il suo ciclo di vita.

B.5.2 Processo di valutazione dell'impatto del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe stabilire un processo per valutare le potenziali conseguenze per gli individui o gruppi di individui, o entrambi, e per la società che possono derivare dal sistema di intelligenza artificiale durante il suo intero ciclo di vita.

Guida all'implementazione

Poiché i sistemi di intelligenza artificiale possono generare un impatto significativo sugli individui, sui gruppi di individui e sulle società, l'organizzazione che fornisce e utilizza tali sistemi dovrebbe, in base allo scopo e all'uso previsti di questi sistemi, valutare i potenziali impatti di questi sistemi su questi gruppi.

L'organizzazione dovrebbe valutare se un sistema di intelligenza artificiale influisce su:

- la posizione giuridica o le opportunità di vita degli individui;
- il benessere fisico o psicologico degli individui;
- diritti umani universali;
- società.

Le procedure dell'organizzazione dovrebbero includere, ma non limitarsi a:

- a) circostanze in cui dovrebbe essere eseguita una valutazione dell'impatto del sistema di IA, che possono includere, ma non sono limitate a:
 - 1) criticità dello scopo previsto e del contesto in cui viene utilizzato il sistema di intelligenza artificiale o qualsiasi aspetto significativo modifiche a questi;
 - 2) la complessità della tecnologia dell'intelligenza artificiale e il livello di automazione dei sistemi di intelligenza artificiale o di qualsiasi aspetto significativo modifiche a ciò;
 - 3) sensibilità dei tipi di dati e delle fonti elaborate dal sistema di intelligenza artificiale o eventuali modifiche significative Quello;
- b) elementi che fanno parte del processo di valutazione dell'impatto del sistema di IA, che possono includere:
 - 1) identificazione (ad esempio fonti, eventi e risultati);
 - 2) analisi (ad esempio conseguenze e probabilità);
 - 3) valutazione (ad esempio decisioni di accettazione e definizione delle priorità);
 - 4) trattamento (ad esempio misure di mitigazione);
 - 5) documentazione, rendicontazione e comunicazione (vedere [7.4](#), [7.5](#) e [B.3.3](#));
- c) chi esegue la valutazione dell'impatto del sistema di IA;
- d) come può essere utilizzata la valutazione dell'impatto del sistema di intelligenza artificiale [ad esempio come può informare la progettazione o l'uso del sistema (vedere [B.6](#) e [B.9](#)), se può avviare revisioni e approvazioni];
- e) individui e società potenzialmente interessati in base allo scopo, all'uso e alle caratteristiche previsti del sistema (ad esempio valutazione per individui, gruppi di individui o società).

La valutazione dell'impatto dovrebbe tenere conto di vari aspetti del sistema di intelligenza artificiale, tra cui i dati utilizzati per lo sviluppo del sistema di intelligenza artificiale, le tecnologie di intelligenza artificiale impiegate e la funzionalità del sistema nel suo complesso.

I processi possono variare in base al ruolo dell'organizzazione e al dominio di applicazione dell'intelligenza artificiale, nonché alle discipline specifiche per cui viene valutato l'impatto (ad esempio sicurezza, privacy e protezione).

Altre informazioni

Per alcune discipline o organizzazioni, la valutazione dettagliata dell'impatto sugli individui o sui gruppi di individui, o su entrambi, e sulla società è parte integrante della gestione del rischio, in particolare in discipline come la sicurezza informatica, la sicurezza e la gestione ambientale. L'organizzazione dovrebbe determinare

se le valutazioni di impatto specifiche per disciplina, eseguite come parte di tale processo di gestione del rischio, integrano sufficientemente le considerazioni dell'IA per quegli aspetti specifici (ad esempio la privacy).

NOTA La norma ISO/IEC 23894 descrive come un'organizzazione può eseguire analisi di impatto per l'organizzazione stessa, insieme a individui o gruppi di individui, o entrambi, e società, come parte di una gestione del rischio complessiva processo.

B.5.3 Documentazione delle valutazioni di impatto del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe documentare i risultati delle valutazioni di impatto del sistema di intelligenza artificiale e conservarli per un periodo di tempo definito.

Guida all'implementazione

La documentazione può essere utile per determinare le informazioni che devono essere comunicate agli utenti e ad altre parti interessate.

Le valutazioni d'impatto del sistema di IA devono essere conservate e aggiornate, se necessario, in linea con gli elementi di una valutazione d'impatto del sistema di IA documentati nella [sezione B.5.2](#). I periodi di conservazione possono seguire i programmi di conservazione dell'organizzazione o essere determinati da requisiti legali o di altro tipo.

Gli elementi che l'organizzazione dovrebbe prendere in considerazione per la documentazione possono includere, ma non sono limitati a:

- l'uso previsto del sistema di IA e qualsiasi uso improprio ragionevolmente prevedibile del sistema di IA;
- impatti positivi e negativi del sistema di intelligenza artificiale sugli individui o sui gruppi di individui interessati, o su entrambi, e sulle società;
- guasti prevedibili, i loro potenziali impatti e misure adottate per mitigarli;
- gruppi demografici rilevanti a cui è applicabile il sistema;
- complessità del sistema;
- il ruolo degli esseri umani nelle relazioni con il sistema, comprese le capacità di supervisione umana, i processi e gli strumenti disponibili per evitare impatti negativi;
- occupazione e qualificazione del personale.

B.5.4 Valutazione dell'impatto del sistema di intelligenza artificiale su individui o gruppi di individui

Controllare

L'organizzazione dovrebbe valutare e documentare i potenziali impatti dei sistemi di intelligenza artificiale sugli individui o sui gruppi di individui durante l'intero ciclo di vita del sistema.

Guida all'implementazione

Nel valutare l'impatto sugli individui o gruppi di individui, o entrambi, e sulla società, l'organizzazione dovrebbe considerare i propri principi di governance, le politiche e gli obiettivi dell'IA. Gli individui che utilizzano il sistema di IA o le cui informazioni personali identificabili (PII) vengono elaborate dal sistema di IA possono avere aspettative relative all'affidabilità del sistema di IA. È necessario tenere conto delle esigenze di protezione specifiche di gruppi come bambini, persone con disabilità, anziani e lavoratori. L'organizzazione dovrebbe valutare tali aspettative e considerare le modalità per soddisfarle nell'ambito della valutazione dell'impatto del sistema.

A seconda dell'ambito di applicazione e di utilizzo del sistema di intelligenza artificiale, le aree di impatto da considerare come parte della valutazione possono includere, a titolo esemplificativo ma non esaustivo:

- correttezza;
- responsabilità;

- trasparenza e spiegabilità;
- sicurezza e privacy;
- sicurezza e salute;
- conseguenze finanziarie;
- accessibilità;
- diritti umani.

Altre informazioni

Se necessario, l'organizzazione dovrebbe consultare esperti (ad esempio ricercatori, esperti in materia e utenti) per ottenere una comprensione completa dei potenziali impatti del sistema di intelligenza artificiale sugli individui o sui gruppi di individui, o su entrambi, e sulle società.

B.5.5 Valutazione dell'impatto sociale dei sistemi di intelligenza artificiale

Controllare

L'organizzazione dovrebbe valutare e documentare i potenziali impatti sociali dei propri sistemi di intelligenza artificiale durante tutto il loro ciclo di vita.

Guida all'implementazione

L'impatto sulla società può variare notevolmente a seconda del contesto dell'organizzazione e dei tipi di sistemi di intelligenza artificiale. L'impatto sociale dei sistemi di intelligenza artificiale può essere sia positivo che negativo. Esempi di questi potenziali impatti sociali includono:

- sostenibilità ambientale (compresi gli impatti sulle risorse naturali e sui gas serra emissioni);
- economico (compreso l'accesso ai servizi finanziari, alle opportunità di lavoro, alle tasse, al commercio e commercio);
- governo (inclusi processi legislativi, disinformazione a scopo di lucro, sicurezza nazionale e sistemi di giustizia penale);
- salute e sicurezza (compreso l'accesso all'assistenza sanitaria, alla diagnosi e al trattamento medico e al potenziale danni fisici e psicologici);
- norme, tradizioni, cultura e valori (inclusa la disinformazione che porta a pregiudizi o danni a individui o gruppi di individui, o entrambi, e società).

Altre informazioni

Lo sviluppo e l'utilizzo di sistemi di intelligenza artificiale (IA) possono richiedere un elevato impiego di risorse computazionali, con conseguenti impatti sulla sostenibilità ambientale (ad esempio, emissioni di gas serra dovute all'aumento del consumo energetico, impatti su acqua, suolo, flora e fauna). Allo stesso modo, i sistemi di IA possono essere utilizzati per migliorare la sostenibilità ambientale di altri sistemi (ad esempio, ridurre le emissioni di gas serra legate a edifici e trasporti). L'organizzazione dovrebbe considerare l'impatto dei propri sistemi di IA nel contesto dei propri obiettivi e strategie complessivi di sostenibilità ambientale.

L'organizzazione dovrebbe valutare come i suoi sistemi di intelligenza artificiale possano essere utilizzati impropriamente per creare danni sociali e come possano essere utilizzati per affrontare danni storici. Ad esempio, i sistemi di intelligenza artificiale possono impedire l'accesso a servizi finanziari come prestiti, sovvenzioni, assicurazioni e investimenti? Allo stesso modo, possono migliorare l'accesso a questi strumenti?

I sistemi di intelligenza artificiale sono stati utilizzati per influenzare i risultati delle elezioni e per creare disinformazione (ad esempio, deepfake nei media digitali) che può portare a disordini politici e sociali. L'uso di sistemi di intelligenza artificiale da parte del governo per scopi di giustizia penale ha esposto il rischio di pregiudizi per società, individui o gruppi di

ISO/IEC 42001:2023(E)

individui. L'organizzazione dovrebbe analizzare come gli attori possano abusare dei sistemi di intelligenza artificiale e come questi possano rafforzare pregiudizi sociali storici indesiderati.

I sistemi di intelligenza artificiale possono essere utilizzati per diagnosticare e curare malattie e per determinare i requisiti per accedere alle prestazioni sanitarie. I sistemi di intelligenza artificiale vengono inoltre impiegati in scenari in cui malfunzionamenti possono causare morte o lesioni alle persone (ad esempio, automobili a guida autonoma e collaborazione uomo-macchina). L'organizzazione dovrebbe considerare sia gli effetti positivi che quelli negativi dell'utilizzo di sistemi di intelligenza artificiale, ad esempio in scenari relativi alla salute e alla sicurezza.

NOTA La norma ISO/IEC TR 24368 fornisce una panoramica di alto livello delle problematiche etiche e sociali relative ai sistemi e alle applicazioni di intelligenza artificiale.

B.6 Ciclo di vita del sistema di intelligenza artificiale

B.6.1 Linee guida di gestione per lo sviluppo del sistema di intelligenza artificiale

B.6.1.1 Obiettivo

Per garantire che l'organizzazione identifichi e documenti gli obiettivi e implementi processi per la progettazione e lo sviluppo responsabili dei sistemi di intelligenza artificiale.

B.6.1.2 Obiettivi per lo sviluppo responsabile del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe identificare e documentare gli obiettivi per orientare lo sviluppo responsabile dei sistemi di intelligenza artificiale, tenerne conto e integrare le misure per conseguirli nel ciclo di vita dello sviluppo.

Guida all'implementazione

L'organizzazione dovrebbe identificare gli obiettivi (vedere [6.2](#)) che influenzano i processi di progettazione e sviluppo del sistema di IA. Questi obiettivi dovrebbero essere presi in considerazione nei processi di progettazione e sviluppo.

Ad esempio, se un'organizzazione definisce "equità" come un obiettivo, questo dovrebbe essere incorporato nella specifica dei requisiti, nell'acquisizione dei dati, nel condizionamento dei dati, nell'addestramento del modello, nella verifica e nella convalida, ecc. L'organizzazione dovrebbe fornire requisiti e linee guida, se necessario, per garantire che le misure siano integrate nelle varie fasi (ad esempio il requisito di utilizzare uno strumento o un metodo di test specifico per affrontare l'ingiustizia o i pregiudizi indesiderati) per raggiungere tali obiettivi.

Altre informazioni

Le tecniche di intelligenza artificiale vengono utilizzate per potenziare le misure di sicurezza, come la previsione delle minacce, il rilevamento e la prevenzione degli attacchi. Questa è un'applicazione delle tecniche di intelligenza artificiale che può essere utilizzata per rafforzare le misure di sicurezza a protezione sia dei sistemi di intelligenza artificiale che dei sistemi software convenzionali non basati su intelligenza artificiale. [Allegato C](#) fornisce esempi di obiettivi organizzativi per la gestione del rischio, che possono essere utili per determinare gli obiettivi per lo sviluppo del sistema di intelligenza artificiale.

B.6.1.3 Processi per la progettazione e lo sviluppo responsabili dei sistemi di intelligenza artificiale

Controllare

L'organizzazione dovrebbe definire e documentare i processi specifici per la progettazione e lo sviluppo responsabili del sistema di intelligenza artificiale.

Guida all'implementazione

Lo sviluppo responsabile dei processi del sistema di intelligenza artificiale dovrebbe includere la considerazione di quanto segue, senza limitazioni:

- fasi del ciclo di vita (un modello generico del ciclo di vita del sistema di intelligenza artificiale è fornito da ISO/IEC 22989, ma l'organizzazione può specificare le proprie fasi del ciclo di vita);
- requisiti di prova e mezzi pianificati per la prova;
- requisiti di supervisione umana, inclusi processi e strumenti, soprattutto quando il sistema di intelligenza artificiale può avere un impatto sulle persone fisiche;
- in quali fasi dovrebbero essere eseguite le valutazioni di impatto del sistema di intelligenza artificiale;
- aspettative e regole sui dati di formazione (ad esempio quali dati possono essere utilizzati, fornitori di dati approvati e etichettatura);
- competenze (dominio della materia o altro) richieste o formazione per gli sviluppatori di sistemi di intelligenza artificiale o Entrambi;
- criteri di rilascio;
- approvazioni e firme necessarie nelle varie fasi;
- controllo delle modifiche;
- usabilità e controllabilità;
- coinvolgimento delle parti interessate.

I processi specifici di progettazione e sviluppo dipendono dalla funzionalità e dalle tecnologie di intelligenza artificiale che si intendono utilizzare per il sistema di intelligenza artificiale.

B.6.2 Ciclo di vita del sistema di intelligenza artificiale

B.6.2.1 Obiettivo

Definire i criteri e i requisiti per ogni fase del ciclo di vita del sistema di intelligenza artificiale.

B.6.2.2 Requisiti e specifiche del sistema AI

Controllare

L'organizzazione dovrebbe specificare e documentare i requisiti per i nuovi sistemi di intelligenza artificiale o per i miglioramenti materiali dei sistemi esistenti.

Guida all'implementazione

L'organizzazione dovrebbe documentare le motivazioni alla base dello sviluppo di un sistema di intelligenza artificiale e i suoi obiettivi. Alcuni dei fattori che dovrebbero essere considerati, documentati e compresi possono includere:

- a) perché il sistema di intelligenza artificiale deve essere sviluppato, ad esempio, è guidato da un caso aziendale, da un cliente richiesta o per politica governativa;
- b) come può essere addestrato il modello e come possono essere soddisfatti i requisiti dei dati.

I requisiti del sistema di IA dovrebbero essere specificati e dovrebbero coprire l'intero ciclo di vita del sistema stesso. Tali requisiti dovrebbero essere rivisti nei casi in cui il sistema di IA sviluppato non sia in grado di funzionare come previsto o emergano nuove informazioni che possano essere utilizzate per modificarne e migliorarne i requisiti. Ad esempio, lo sviluppo del sistema di IA potrebbe diventare irrealizzabile dal punto di vista finanziario.

ISO/IEC 42001:2023(E)

Altre informazioni

I processi per descrivere il ciclo di vita del sistema di intelligenza artificiale sono forniti dalla norma ISO/IEC 5338. Per ulteriori informazioni sulla progettazione incentrata sull'uomo per i sistemi interattivi, consultare la norma ISO 9241-210.

B.6.2.3 Documentazione della progettazione e dello sviluppo del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe documentare la progettazione e lo sviluppo del sistema di intelligenza artificiale sulla base degli obiettivi organizzativi, dei requisiti documentati e dei criteri di specifica.

Guida all'implementazione

Sono numerose le scelte di progettazione necessarie per un sistema di intelligenza artificiale, tra cui, a titolo esemplificativo ma non esaustivo:

- approccio di apprendimento automatico (ad esempio supervisionato vs. non supervisionato);
- algoritmo di apprendimento e tipo di modello di apprendimento automatico utilizzato;
- come si intende addestrare il modello e quale qualità dei dati (vedere [B.7](#));
- valutazione e perfezionamento dei modelli;
- componenti hardware e software;
- minacce alla sicurezza considerate durante l'intero ciclo di vita del sistema di intelligenza artificiale; minacce alla sicurezza specifiche dell'intelligenza artificiale i sistemi includono attacchi di avvelenamento dei dati, furto di modelli o inversione di modelli;
- interfaccia e presentazione degli output;
- come gli esseri umani possono interagire con il sistema;
- considerazioni sull'interoperabilità e sulla portabilità.

Possono esserci più iterazioni tra progettazione e sviluppo, ma la documentazione in fase di sviluppo dovrebbe essere mantenuta e dovrebbe essere disponibile una documentazione finale sull'architettura del sistema.

Altre informazioni

Per maggiori informazioni sulla progettazione incentrata sull'uomo per sistemi interattivi, vedere ISO 9241-210.

B.6.2.4 Verifica e convalida del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe definire e documentare misure di verifica e convalida per il sistema di intelligenza artificiale e specificare criteri per il loro utilizzo.

Guida all'implementazione

Le misure di verifica e convalida possono includere, ma non sono limitate a:

- metodologie e strumenti di test;
- selezione dei dati di prova e loro rappresentazione del dominio di utilizzo previsto;
- requisiti dei criteri di rilascio.

L'organizzazione dovrebbe definire e documentare criteri di valutazione quali, a titolo esemplificativo ma non esaustivo:

- un piano per valutare i componenti del sistema di intelligenza artificiale e l'intero sistema di intelligenza artificiale per i rischi correlati agli impatti sugli individui o sui gruppi di individui, o su entrambi, e sulle società;

- il piano di valutazione può basarsi, ad esempio:
 - requisiti di affidabilità e sicurezza del sistema di intelligenza artificiale, compresi tassi di errore accettabili per le prestazioni del sistema di intelligenza artificiale;
 - obiettivi di sviluppo e utilizzo responsabile del sistema di intelligenza artificiale come quelli indicati in [B.6.1.2](#) e [B.9.3](#); _____
 - fattori operativi quali la qualità dei dati, l'uso previsto, compresi gli intervalli accettabili di ciascuno fattore operativo;
 - qualsiasi utilizzo previsto che possa richiedere la definizione di fattori operativi più rigorosi, compresi diversi intervalli accettabili per i fattori operativi o tassi di errore più bassi;
- i metodi, gli orientamenti o le metriche da utilizzare per valutare se le parti interessate che prendono decisioni o sono soggette a decisioni basate sui risultati del sistema di IA siano in grado di interpretare adeguatamente i risultati del sistema di IA. La frequenza della valutazione dovrebbe essere determinata e può basarsi sui risultati di una valutazione d'impatto del sistema di IA;
- eventuali fattori accettabili che possano spiegare l'incapacità di raggiungere un livello minimo di prestazioni, in particolare quando il sistema di IA viene valutato per l'impatto su individui o gruppi di individui, o entrambi, e sulla società (ad esempio, scarsa risoluzione delle immagini per i sistemi di visione artificiale o rumore di fondo che influisce sui sistemi di riconoscimento vocale). È necessario documentare anche i meccanismi per gestire le scarse prestazioni del sistema di IA derivanti da questi fattori.

Il sistema di intelligenza artificiale dovrebbe essere valutato in base ai criteri di valutazione documentati.

Laddove il sistema di IA non riesca a soddisfare i criteri documentati per la valutazione, in particolare rispetto agli obiettivi di sviluppo e utilizzo responsabile del sistema di IA (vedere [B.6.1.2](#) e [B.9.3](#)), l'organizzazione dovrebbe riconsiderare o gestire le carenze dell'uso previsto del sistema di IA, i suoi requisiti di prestazione e il modo in cui l'organizzazione può affrontare efficacemente gli impatti sugli individui o gruppi di individui, o entrambi, e sulle società.

NOTA Ulteriori informazioni su come gestire la robustezza delle reti neurali sono disponibili nella norma ISO/IEC TR 24029-1.

B.6.2.5 Distribuzione del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe documentare un piano di distribuzione e garantire che vengano soddisfatti i requisiti appropriati prima della distribuzione.

Guida all'implementazione

I sistemi di intelligenza artificiale possono essere sviluppati in diversi ambienti e implementati in altri (ad esempio, sviluppati on-premise e implementati tramite cloud computing) e l'organizzazione dovrebbe tenere conto di queste differenze nel piano di implementazione. L'organizzazione dovrebbe anche valutare se i componenti vengono implementati separatamente (ad esempio, software e modello possono essere implementati in modo indipendente). Inoltre, l'organizzazione dovrebbe disporre di una serie di requisiti da soddisfare prima del rilascio e dell'implementazione (a volte denominati "criteri di rilascio"). Questi possono includere misure di verifica e convalida da superare, metriche di performance da soddisfare, test utente da completare, nonché approvazioni e autorizzazioni da ottenere da parte del management. Il piano di implementazione dovrebbe tenere conto delle prospettive e degli impatti per le parti interessate.

B.6.2.6 Funzionamento e monitoraggio del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe definire e documentare gli elementi necessari per il funzionamento continuo del sistema di intelligenza artificiale. Come minimo, ciò dovrebbe includere il monitoraggio del sistema e delle prestazioni, le riparazioni, gli aggiornamenti e il supporto.

ISO/IEC 42001:2023(E)

Guida all'implementazione

Ogni attività minima di gestione e monitoraggio può tenere conto di diverse considerazioni. Ad esempio:

- Il monitoraggio del sistema e delle prestazioni può includere il monitoraggio di errori e guasti generali, nonché il monitoraggio delle prestazioni del sistema secondo le aspettative in relazione ai dati di produzione. I criteri di prestazione tecnica possono includere i tassi di successo nella risoluzione dei problemi o nel completamento delle attività, oppure i tassi di affidabilità. Altri criteri possono essere correlati al rispetto degli impegni o delle aspettative e delle esigenze delle parti interessate, tra cui, ad esempio, il monitoraggio continuo per garantire la conformità ai requisiti del cliente o ai requisiti legali applicabili.
- Alcuni sistemi di intelligenza artificiale implementati evolvono le loro prestazioni grazie al ML, dove i dati di produzione e i dati di output vengono utilizzati per addestrare ulteriormente il modello di ML. Laddove si utilizzi l'apprendimento continuo, l'organizzazione dovrebbe monitorare le prestazioni del sistema di intelligenza artificiale per garantire che continui a soddisfare gli obiettivi di progettazione e a operare sui dati di produzione come previsto.
- Le prestazioni di alcuni sistemi di intelligenza artificiale possono variare anche se non utilizzano l'apprendimento continuo, solitamente a causa di derive concettuali o di dati nei dati di produzione. In questi casi, il monitoraggio può identificare la necessità di un riaddestramento per garantire che il sistema di intelligenza artificiale continui a soddisfare gli obiettivi di progettazione e a operare sui dati di produzione come previsto. Ulteriori informazioni sono disponibili nella norma ISO/IEC 23053.
- Le riparazioni possono includere risposte a errori e guasti del sistema. L'organizzazione dovrebbe disporre di processi per la risposta e la riparazione di questi problemi. Inoltre, potrebbero rendersi necessari aggiornamenti man mano che il sistema si evolve, quando vengono identificati problemi critici o a seguito di problemi identificati esternamente (ad esempio, non conformità alle aspettative dei clienti o ai requisiti legali). Dovrebbero essere implementati processi per l'aggiornamento del sistema, inclusi i componenti interessati, la pianificazione degli aggiornamenti e le informazioni agli utenti sui contenuti dell'aggiornamento.
- Gli aggiornamenti di sistema possono includere anche modifiche al funzionamento del sistema, nuovi o modificati utilizzi previsti o altre modifiche alle funzionalità del sistema. L'organizzazione dovrebbe disporre di procedure per gestire le modifiche operative, inclusa la comunicazione agli utenti.
- Il supporto per il sistema può essere interno, esterno o entrambi, a seconda delle esigenze dell'organizzazione e delle modalità di acquisizione del sistema. I processi di supporto dovrebbero considerare come gli utenti possono contattare l'assistenza appropriata, come vengono segnalati problemi e incidenti, gli accordi sul livello di servizio e le metriche di supporto.
- Laddove i sistemi di intelligenza artificiale vengano utilizzati per scopi diversi da quelli per cui sono stati progettati o in modi non previsti, si dovrebbe valutare l'adeguatezza di tali usi.
- È necessario identificare le minacce alla sicurezza informatica specifiche dell'IA relative ai sistemi di IA applicati e sviluppati dall'organizzazione. Le minacce alla sicurezza informatica specifiche dell'IA includono, a titolo esemplificativo ma non esaustivo, l'avvelenamento dei dati, il furto di modelli e gli attacchi di inversione di modelli.

Altre informazioni

L'organizzazione dovrebbe considerare le prestazioni operative che possono avere effetti sulle parti interessate e tenerne conto quando progetta e determina i criteri di prestazione.

I criteri di prestazione per i sistemi di intelligenza artificiale in funzione dovrebbero essere determinati dal compito in esame, come la classificazione, la regressione, la classificazione, il clustering o la riduzione della dimensionalità.

I criteri di prestazione possono includere aspetti statistici quali tassi di errore e durata dell'elaborazione.

Per ciascun criterio, l'organizzazione dovrebbe identificare tutte le metriche rilevanti e le interdipendenze tra di esse. Per ciascuna metrica, l'organizzazione dovrebbe considerare valori accettabili basati, ad esempio, sulle raccomandazioni di esperti del settore e sull'analisi delle aspettative delle parti interessate rispetto alle pratiche non legate all'intelligenza artificiale esistenti.

Ad esempio, un'organizzazione può determinare che il punteggio F1 è una metrica di prestazione appropriata in base alla sua valutazione dell'impatto dei falsi positivi e dei falsi negativi, come descritto in

ISO/IEC TS 4213. L'organizzazione può quindi stabilire un valore F1 che il sistema di IA dovrebbe rispettare. È necessario valutare se queste problematiche possano essere gestite dalle misure esistenti. In caso contrario, si dovrebbero valutare modifiche alle misure esistenti o definire misure aggiuntive per individuare e gestire tali problematiche.

L'organizzazione dovrebbe considerare le prestazioni dei sistemi o processi non basati sull'intelligenza artificiale in funzione e utilizzarli come contesto potenzialmente rilevante quando stabilisce i criteri di prestazione.

L'organizzazione dovrebbe inoltre garantire che i mezzi e i processi utilizzati per valutare il sistema di IA, inclusi, ove applicabile, la selezione e la gestione dei dati di valutazione, migliorino la completezza e l'affidabilità nella valutazione delle sue prestazioni rispetto ai criteri definiti.

Lo sviluppo di metodologie di valutazione delle prestazioni può basarsi su criteri, parametri e valori.

Questi dovrebbero fornire informazioni sulla quantità di dati e sui tipi di processi utilizzati nella valutazione, nonché sui ruoli e le competenze del personale che esegue la valutazione.

Le metodologie di valutazione delle prestazioni dovrebbero riflettere il più fedelmente possibile gli attributi e le caratteristiche del funzionamento e dell'utilizzo, al fine di garantire che i risultati della valutazione siano utili e pertinenti. Alcuni aspetti della valutazione delle prestazioni possono richiedere l'introduzione controllata di dati o processi errati o spuri per valutarne l'impatto sulle prestazioni.

Il modello di qualità ISO/IEC 25059 può essere utilizzato per definire criteri di prestazione.

B.6.2.7 Documentazione tecnica del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe determinare quale documentazione tecnica del sistema di intelligenza artificiale sia necessaria per ciascuna categoria rilevante di parti interessate, quali utenti, partner, autorità di vigilanza, e fornire loro la documentazione tecnica nella forma appropriata.

Guida all'implementazione

La documentazione tecnica del sistema di intelligenza artificiale può includere, a titolo esemplificativo ma non esaustivo, i seguenti elementi:

- una descrizione generale del sistema di intelligenza artificiale, compreso lo scopo previsto;
- istruzioni per l'uso;
- ipotesi tecniche sulla sua distribuzione e sul suo funzionamento (ambiente di runtime, software correlato e capacità hardware, ipotesi fatte sui dati, ecc.);
- limitazioni tecniche (ad esempio tassi di errore accettabili, accuratezza, affidabilità, robustezza);
- capacità e funzioni di monitoraggio che consentono agli utenti o agli operatori di influenzare il sistema operazione.

Gli elementi di documentazione relativi a tutte le fasi del ciclo di vita del sistema di intelligenza artificiale (come definiti in ISO/IEC 22989) possono includere, ma non sono limitati a:

- progettazione e specifiche dell'architettura del sistema;
- scelte progettuali effettuate e misure di qualità adottate durante il processo di sviluppo del sistema;
- informazioni sui dati utilizzati durante lo sviluppo del sistema;
- ipotesi formulate e misure di qualità adottate sulla qualità dei dati (ad esempio distribuzioni statistiche ipotizzate);
- attività di gestione (ad esempio gestione del rischio) intraprese durante lo sviluppo o il funzionamento dell'IA sistema;
- registrazioni di verifica e convalida;

ISO/IEC 42001:2023(E)

- modifiche apportate al sistema di intelligenza artificiale quando è in funzione;
- documentazione di valutazione dell'impatto come descritto in [B.5](#).

L'organizzazione dovrebbe documentare le informazioni tecniche relative al funzionamento responsabile del sistema di intelligenza artificiale. Queste possono includere, a titolo esemplificativo ma non esaustivo:

- documentare un piano per la gestione dei guasti. Ciò può includere, ad esempio, la necessità di descrivere un piano di rollback per il sistema di intelligenza artificiale, la disattivazione di funzionalità del sistema di intelligenza artificiale, un processo di aggiornamento o un piano per la notifica a clienti, utenti, ecc. di modifiche al sistema di intelligenza artificiale, informazioni aggiornate sui guasti del sistema e su come questi possano essere mitigati;
- documentare i processi per monitorare lo stato di salute del sistema di intelligenza artificiale (vale a dire che il sistema di intelligenza artificiale funziona come previsto e entro i suoi normali margini operativi, noti anche come osservabilità) e i processi per affrontare i guasti del sistema di intelligenza artificiale;
- documentare le procedure operative standard per il sistema di intelligenza artificiale, inclusi gli eventi da monitorare e le modalità di prioritizzazione e revisione dei registri eventi. Può anche includere le modalità di indagine e prevenzione dei guasti;
- documentare i ruoli del personale responsabile del funzionamento del sistema di intelligenza artificiale nonché di quelli responsabili della rendicontazione dell'uso del sistema, in particolare in relazione alla gestione degli effetti dei guasti del sistema di intelligenza artificiale o alla gestione degli aggiornamenti del sistema di intelligenza artificiale;
- documentazione degli aggiornamenti del sistema quali modifiche nelle operazioni del sistema, nuovi o modificati utilizzi previsti o altre modifiche nelle funzionalità del sistema.

L'organizzazione dovrebbe disporre di procedure per gestire i cambiamenti operativi, tra cui la comunicazione agli utenti e le valutazioni interne sul tipo di cambiamento.

La documentazione deve essere aggiornata e accurata. Deve essere approvata dal management competente all'interno dell'organizzazione.

Se forniti come parte della documentazione utente, i controlli indicati nella [Tabella A.1](#) devono essere presi in considerazione.

B.6.2.8 Registrazione dei registri degli eventi da parte del sistema AI

Controllare

L'organizzazione dovrebbe stabilire in quali fasi del ciclo di vita del sistema di intelligenza artificiale abilitare la tenuta dei registri degli eventi, ma almeno quando il sistema di intelligenza artificiale è in uso.

Guida all'implementazione

L'organizzazione dovrebbe garantire la registrazione dei dati per i sistemi di intelligenza artificiale implementati, al fine di raccogliere e registrare automaticamente i log degli eventi relativi a determinati eventi che si verificano durante il funzionamento. Tale registrazione può includere, a titolo esemplificativo ma non esaustivo:

- tracciabilità della funzionalità del sistema di intelligenza artificiale per garantire che il sistema di intelligenza artificiale funzioni come previsto;
- rilevamento delle prestazioni del sistema di IA al di fuori delle condizioni operative previste per lo stesso, che possono comportare prestazioni indesiderate sui dati di produzione o impatti sulle parti interessate rilevanti attraverso il monitoraggio del funzionamento del sistema di IA.

I registri degli eventi del sistema di intelligenza artificiale possono includere informazioni quali l'ora e la data di ogni utilizzo del sistema di intelligenza artificiale, i dati di produzione su cui opera il sistema di intelligenza artificiale, gli output che esulano dall'intervallo di funzionamento previsto del sistema di intelligenza artificiale, ecc.

I registri degli eventi devono essere conservati per tutto il tempo necessario all'uso previsto del sistema di intelligenza artificiale e nel rispetto delle policy di conservazione dei dati dell'organizzazione. Possono essere applicati i requisiti legali relativi alla conservazione dei dati.

Altre informazioni

Alcuni sistemi di intelligenza artificiale, come i sistemi di identificazione biometrica, possono prevedere requisiti di registrazione aggiuntivi a seconda della giurisdizione. Le organizzazioni devono essere a conoscenza di questi requisiti.

B.7 Dati per i sistemi di intelligenza artificiale

B.7.1 Obiettivo

Per garantire che l'organizzazione comprenda il ruolo e l'impatto dei dati nei sistemi di intelligenza artificiale nell'applicazione e nello sviluppo, nella fornitura o nell'uso dei sistemi di intelligenza artificiale durante il loro ciclo di vita.

B.7.2 Dati per lo sviluppo e il miglioramento del sistema di intelligenza artificiale

Controllare

L'organizzazione dovrebbe definire, documentare e implementare processi di gestione dei dati correlati allo sviluppo di sistemi di intelligenza artificiale.

Guida all'implementazione

La gestione dei dati può includere vari argomenti, tra cui:

- implicazioni sulla privacy e sulla sicurezza dovute all'uso di dati, alcuni dei quali possono essere di natura sensibile;
- minacce alla sicurezza e alla protezione che possono derivare dallo sviluppo di sistemi di intelligenza artificiale dipendenti dai dati;
- aspetti di trasparenza e spiegabilità, tra cui la provenienza dei dati e la capacità di fornire una spiegazione di come i dati vengono utilizzati per determinare l'output di un sistema di intelligenza artificiale se il sistema richiede trasparenza e spiegabilità;
- rappresentatività dei dati di formazione rispetto al dominio operativo di utilizzo;
- accuratezza e integrità dei dati.

NOTA Informazioni dettagliate sul ciclo di vita del sistema di intelligenza artificiale e sui concetti di gestione dei dati sono fornite dalla norma ISO/IEC 22989.

B.7.3 Acquisizione dei dati

Controllare

L'organizzazione dovrebbe determinare e documentare i dettagli relativi all'acquisizione e alla selezione dei dati utilizzati nei sistemi di intelligenza artificiale.

Guida all'implementazione

L'organizzazione può aver bisogno di diverse categorie di dati da diverse fonti a seconda dell'ambito e dell'utilizzo dei propri sistemi di intelligenza artificiale. I dettagli per l'acquisizione dei dati possono includere:

- categorie di dati necessari per il sistema di intelligenza artificiale;
- quantità di dati necessari;
- fonti di dati (ad esempio dati interni, acquistati, condivisi, aperti, sintetici);
- caratteristiche della fonte dei dati (ad esempio statici, trasmessi in streaming, raccolti, generati dalla macchina);
- dati demografici e caratteristiche dell'interessato (ad esempio pregiudizi noti o potenziali o altri dati sistematici errori);
- il trattamento precedente dei dati (ad esempio utilizzi precedenti, conformità ai requisiti di privacy e sicurezza);

ISO/IEC 42001:2023(E)

- diritti sui dati (ad esempio PII, copyright);
- metadati associati (ad esempio dettagli sull'etichettatura e il miglioramento dei dati);
- provenienza dei dati.

Altre informazioni

Le categorie di dati e una struttura per l'uso dei dati in ISO/IEC 19944-1 possono essere utilizzate per documentare i dettagli sull'acquisizione e l'uso dei dati.

B.7.4 Qualità dei dati per i sistemi di intelligenza artificiale

Controllare

L'organizzazione dovrebbe definire e documentare i requisiti per la qualità dei dati e garantire che i dati utilizzati per sviluppare e gestire il sistema di intelligenza artificiale soddisfino tali requisiti.

Guida all'implementazione

La qualità dei dati utilizzati per sviluppare e gestire i sistemi di intelligenza artificiale ha potenzialmente un impatto significativo sulla validità dei risultati del sistema. La norma ISO/IEC 25024 definisce la qualità dei dati come il grado in cui le caratteristiche dei dati soddisfano le esigenze dichiarate e implicite quando utilizzate in condizioni specifiche. Per i sistemi di intelligenza artificiale che utilizzano l'apprendimento automatico supervisionato o semi-supervisionato, è importante che la qualità dei dati di addestramento, convalida, test e produzione sia definita, misurata e migliorata nella misura possibile, e l'organizzazione dovrebbe garantire che i dati siano adatti allo scopo previsto. L'organizzazione dovrebbe considerare l'impatto dei bias sulle prestazioni e sull'equità del sistema e apportare le modifiche necessarie al modello e ai dati utilizzati per migliorare le prestazioni e l'equità, in modo che siano accettabili per il caso d'uso.

Altre informazioni

Ulteriori informazioni sulla qualità dei dati sono disponibili nella serie ISO/IEC 52592) sulla qualità dei dati per l'analisi e il machine learning. Ulteriori informazioni sulle diverse forme di bias nei dati utilizzati nei sistemi di intelligenza artificiale sono disponibili nella norma ISO/IEC TR 24027.

B.7.5 Provenienza dei dati

Controllare

L'organizzazione dovrebbe definire e documentare un processo per registrare la provenienza dei dati utilizzati nei suoi sistemi di intelligenza artificiale durante l'intero ciclo di vita dei dati e del sistema di intelligenza artificiale.

Guida all'implementazione

Secondo la norma ISO 8000-2, un registro della provenienza dei dati può includere informazioni sulla creazione, l'aggiornamento, la trascrizione, l'astrazione, la convalida e il trasferimento del controllo dei dati. Inoltre, la condivisione dei dati (senza trasferimento del controllo) e le trasformazioni dei dati possono essere considerate nell'ambito della provenienza dei dati. A seconda di fattori quali la fonte dei dati, il loro contenuto e il contesto del loro utilizzo, le organizzazioni dovrebbero valutare se siano necessarie misure per verificare la provenienza dei dati.

B.7.6 Preparazione dei dati

Controllare

L'organizzazione deve definire e documentare i propri criteri per la selezione delle preparazioni dei dati e i metodi di preparazione dei dati da utilizzare.

Guida all'implementazione

I dati utilizzati in un sistema di intelligenza artificiale necessitano normalmente di una preparazione per essere utilizzabili per un determinato compito di intelligenza artificiale. Ad esempio, gli algoritmi di apprendimento automatico a volte non tollerano voci mancanti o errate, non

Distribuzione normale e scale ampiamente variabili. Metodi di preparazione e trasformazioni possono essere utilizzati per migliorare la qualità dei dati. Una preparazione non adeguata dei dati può potenzialmente portare a errori nei sistemi di intelligenza artificiale. I metodi di preparazione e le trasformazioni più comuni per i dati utilizzati nei sistemi di intelligenza artificiale includono:

- esplorazione statistica dei dati (ad esempio distribuzione, media, mediana, deviazione standard, intervallo, stratificazione, campionamento) e metadati statistici (ad esempio specifiche dell'iniziativa di documentazione dei dati (DDI)[28]);
- pulizia (ad esempio correzione delle voci, gestione delle voci mancanti);
- imputazione (vale a dire metodi per colmare le voci mancanti);
- normalizzazione;
- ridimensionamento;
- etichettatura delle variabili target;
- codifica (ad esempio conversione di variabili categoriali in numeri).

Per una determinata attività di intelligenza artificiale, l'organizzazione dovrebbe documentare i propri criteri per la selezione di specifici metodi di preparazione dei dati e delle trasformazioni, nonché i metodi e le trasformazioni specifici utilizzati nell'attività di intelligenza artificiale.

NOTA Per ulteriori informazioni sulla preparazione dei dati specifica per l'apprendimento automatico, vedere la serie ISO/IEC 52592) e ISO/IEC 23053.

B.8 Informazioni per le parti interessate

B.8.1 Obiettivo

Per garantire che le parti interessate dispongano delle informazioni necessarie per comprendere e valutare i rischi e i loro impatti (sia positivi che negativi).

B.8.2 Documentazione e informazioni di sistema per gli utenti

Controllare

L'organizzazione dovrebbe determinare e fornire le informazioni necessarie agli utenti del sistema.

Guida all'implementazione

Le informazioni sul sistema di intelligenza artificiale possono includere sia dettagli tecnici che istruzioni, nonché notifiche generali agli utenti che stanno interagendo con un sistema di intelligenza artificiale, a seconda del contesto. Questo può includere anche il sistema stesso, nonché i potenziali output del sistema (ad esempio, la notifica agli utenti che un'immagine è stata creata dall'intelligenza artificiale).

Sebbene i sistemi di intelligenza artificiale possano essere complessi, è fondamentale che gli utenti siano in grado di comprendere come funziona un sistema di intelligenza artificiale quando interagiscono con esso. Gli utenti devono anche comprenderne lo scopo e gli utilizzi previsti, nonché il suo potenziale di causare danni o benefici per l'utente. Parte della documentazione di sistema può essere necessariamente destinata a usi più tecnici (ad esempio, amministratori di sistema) e l'organizzazione dovrebbe comprendere le esigenze delle diverse parti interessate e il significato che la comprensibilità può avere per loro. Le informazioni dovrebbero inoltre essere accessibili, sia in termini di facilità d'uso nel reperimento delle stesse, sia per gli utenti che potrebbero necessitare di funzionalità di accessibilità aggiuntive.

Le informazioni che possono essere fornite agli utenti includono, ma non sono limitate a:

- scopo del sistema;
- che l'utente interagisca con un sistema di intelligenza artificiale;
- come interagire con il sistema;

ISO/IEC 42001:2023(E)

- come e quando ignorare il sistema;
- requisiti tecnici per il funzionamento del sistema, comprese le risorse di calcolo necessarie, e limitazioni del sistema nonché della sua durata prevista;
- necessità di supervisione umana;
- informazioni sull'accuratezza e sulle prestazioni;
- informazioni rilevanti dalla valutazione d'impatto, compresi potenziali benefici e danni, in particolare se applicabili in contesti specifici o a determinati gruppi demografici (vedere [B.5.2](#) e [B.5.4](#));
- revisioni delle affermazioni sui benefici del sistema;
- aggiornamenti e modifiche al funzionamento del sistema, nonché eventuali misure di manutenzione necessarie, compresa la loro frequenza;
- informazioni sui contatti;
- materiali didattici per l'uso del sistema.

I criteri utilizzati dall'organizzazione per determinare se e quali informazioni debbano essere fornite devono essere documentati. I criteri rilevanti includono, a titolo esemplificativo ma non esaustivo, l'uso previsto e l'uso improprio ragionevolmente prevedibile del sistema di IA, le competenze dell'utente e l'impatto specifico del sistema di IA.

Le informazioni possono essere fornite agli utenti in vari modi, tra cui istruzioni per l'uso documentate, avvisi e altre notifiche integrate nel sistema stesso, informazioni su una pagina web, ecc. A seconda dei metodi utilizzati dall'organizzazione per fornire le informazioni, è necessario verificare che gli utenti abbiano accesso a tali informazioni e che le informazioni fornite siano complete, aggiornate e accurate.

B.8.3 Rendicontazione esterna

Controllare

L'organizzazione dovrebbe fornire alle parti interessate gli strumenti per segnalare gli impatti negativi del sistema.

Guida all'implementazione

Sebbene il funzionamento del sistema debba essere monitorato per individuare problemi e guasti segnalati, l'organizzazione dovrebbe anche fornire agli utenti o ad altre parti esterne la possibilità di segnalare impatti negativi (ad esempio ingiustizia).

B.8.4 Comunicazione degli incidenti

Controllare

L'organizzazione dovrebbe stabilire e documentare un piano per comunicare gli incidenti agli utenti del sistema.

Guida all'implementazione

Gli incidenti relativi al sistema di IA possono essere specifici del sistema stesso o relativi alla sicurezza informatica o alla privacy (ad esempio, una violazione dei dati). L'organizzazione deve comprendere i propri obblighi in materia di notifica degli incidenti agli utenti e alle altre parti interessate, a seconda del contesto in cui opera il sistema. Ad esempio, un incidente con un componente di IA che fa parte di un prodotto e che influisce sulla sicurezza può prevedere requisiti di notifica diversi rispetto ad altri tipi di sistemi. Possono essere applicati requisiti legali (come i contratti) e attività normative, che possono specificare i requisiti per:

- tipologie di incidenti che devono essere comunicati;

- la tempistica per la notifica;
- se e quali autorità devono essere informate;
- i dettagli che devono essere comunicati.

L'organizzazione può integrare le attività di risposta agli incidenti e di segnalazione per l'IA nelle sue più ampie attività di gestione degli incidenti organizzativi, ma deve essere consapevole dei requisiti specifici relativi ai sistemi di IA o ai singoli componenti dei sistemi di IA (ad esempio, una violazione dei dati PII nei dati di addestramento per il sistema può avere requisiti di segnalazione diversi relativi alla privacy).

Altre informazioni

ISO/IEC 27001 e ISO/IEC 27701 forniscono ulteriori dettagli sulla gestione degli incidenti, rispettivamente per quanto riguarda la sicurezza e la privacy.

B.8.5 Informazioni per le parti interessate

Controllare

L'organizzazione dovrebbe determinare e documentare i propri obblighi di comunicazione delle informazioni sul sistema di intelligenza artificiale alle parti interessate.

Guida all'implementazione

In alcuni casi, una giurisdizione può richiedere che le informazioni sul sistema siano condivise con autorità come le autorità di regolamentazione. Le informazioni possono essere comunicate alle parti interessate, come i clienti o le autorità di regolamentazione, entro i termini previsti. Le informazioni condivise possono includere, ad esempio:

- documentazione del sistema tecnico, inclusi, a titolo esemplificativo ma non esaustivo, set di dati per la formazione, la convalida e il collaudo, nonché giustificazioni delle scelte algoritmiche e registri di verifica e convalida;
- rischi connessi al sistema;
- risultati delle valutazioni d'impatto;
- registri e altre registrazioni di sistema.

L'organizzazione deve comprendere i propri obblighi in tal senso e garantire che le informazioni appropriate siano condivise con le autorità competenti. Inoltre, si presuppone che l'organizzazione sia a conoscenza dei requisiti giurisdizionali relativi alle informazioni condivise con le autorità di polizia.

B.9 Utilizzo di sistemi di intelligenza artificiale

B.9.1 Obiettivo

Per garantire che l'organizzazione utilizzi i sistemi di intelligenza artificiale in modo responsabile e conforme alle policy aziendali.

B.9.2 Processi per l'uso responsabile dei sistemi di intelligenza artificiale

Controllare

L'organizzazione dovrebbe definire e documentare i processi per l'uso responsabile dei sistemi di intelligenza artificiale.

Guida all'implementazione

A seconda del contesto, l'organizzazione può tenere conto di numerose considerazioni per decidere se utilizzare o meno un determinato sistema di IA. Che il sistema di IA sia sviluppato dall'organizzazione stessa o fornito da terze parti, l'organizzazione deve avere ben chiare queste considerazioni e sviluppare policy per affrontarle. Alcuni esempi sono:

- le approvazioni richieste;

ISO/IEC 42001:2023(E)

- costi (compresi quelli per il monitoraggio e la manutenzione continui);
- requisiti di approvvigionamento approvati;
- requisiti legali applicabili all'organizzazione.

Nei casi in cui l'organizzazione abbia accettato policy per l'uso di altri sistemi, risorse, ecc., tali policy possono essere incorporate, se lo si desidera.

B.9.3 Obiettivi per un uso responsabile del sistema di intelligenza artificiale**Controllare**

L'organizzazione dovrebbe identificare e documentare gli obiettivi per orientare l'uso responsabile dei sistemi di intelligenza artificiale.

Guida all'implementazione

Le organizzazioni che operano in contesti diversi possono avere aspettative e obiettivi diversi in merito a ciò che costituisce lo sviluppo responsabile dei sistemi di IA. A seconda del contesto, l'organizzazione dovrebbe identificare i propri obiettivi relativi all'uso responsabile. Alcuni obiettivi includono:

- correttezza;
- responsabilità;
- trasparenza;
- spiegabilità;
- affidabilità;
- sicurezza;
- robustezza e ridondanza;
- privacy e sicurezza;
- accessibilità.

Una volta definiti, l'organizzazione dovrebbe implementare meccanismi per raggiungere i propri obiettivi al suo interno. Questo può includere la valutazione se una soluzione di terze parti soddisfa gli obiettivi dell'organizzazione o se una soluzione sviluppata internamente è applicabile all'uso previsto. L'organizzazione dovrebbe determinare in quali fasi del ciclo di vita del sistema di IA integrare obiettivi significativi di supervisione umana. Questo può includere:

- coinvolgere revisori umani per verificare gli output del sistema di intelligenza artificiale, compresa l'autorità di annullare le decisioni prese dal sistema di intelligenza artificiale;
- garantire che sia inclusa la supervisione umana, se richiesta per un utilizzo accettabile del sistema di IA secondo le istruzioni o altra documentazione associata all'implementazione prevista del sistema di IA;
- monitorare le prestazioni del sistema di intelligenza artificiale, compresa l'accuratezza dei risultati del sistema di intelligenza artificiale;
- segnalazione di preoccupazioni relative agli output del sistema di intelligenza artificiale e al loro impatto sui soggetti interessati rilevanti feste;
- segnalazione di preoccupazioni relative a cambiamenti nelle prestazioni o nella capacità del sistema di intelligenza artificiale di effettuare azioni corrette output sui dati di produzione;
- valutare se il processo decisionale automatizzato sia appropriato per un approccio responsabile alla
utilizzo di un sistema di intelligenza artificiale e utilizzo previsto del sistema di intelligenza artificiale.

La necessità di supervisione umana può essere determinata dalle valutazioni d'impatto del sistema di IA (vedere [B.5](#)). Il personale coinvolto nelle attività di supervisione umana relative al sistema di IA dovrebbe essere informato e formato.

e comprendere le istruzioni e la documentazione del sistema di intelligenza artificiale, nonché le attività che questi svolgono per soddisfare gli obiettivi di supervisione umana. Quando si segnalano problemi di prestazioni, la supervisione umana può integrare il monitoraggio automatizzato.

Altre informazioni

[L'allegato C](#) fornisce esempi di obiettivi organizzativi per la gestione del rischio, che possono essere utili per determinare gli obiettivi per l'utilizzo del sistema di intelligenza artificiale.

B.9.4 Uso previsto del sistema di IA

Controllare

L'organizzazione deve garantire che il sistema di intelligenza artificiale venga utilizzato secondo gli usi previsti e nella documentazione allegata.

Guida all'implementazione

Il sistema di IA deve essere implementato secondo le istruzioni e la documentazione ad esso associata (vedere [B.8.2](#)).

L'implementazione può richiedere risorse specifiche a supporto, inclusa la necessità di garantire l'applicazione della supervisione umana come richiesto (vedere [B.9.3](#)). Per un utilizzo accettabile del sistema di IA, può essere necessario che i dati su cui il sistema viene utilizzato siano conformi alla documentazione ad esso associata, al fine di garantire l'accuratezza delle prestazioni del sistema di IA.

Il funzionamento del sistema di IA deve essere monitorato (vedere [B.6.2.6](#)). Qualora la corretta implementazione del sistema di IA secondo le istruzioni associate desti preoccupazioni in merito all'impatto sulle parti interessate o ai requisiti legali dell'organizzazione, quest'ultima dovrebbe comunicare le proprie preoccupazioni al personale competente all'interno dell'organizzazione, nonché a eventuali fornitori terzi del sistema di IA.

L'organizzazione dovrebbe conservare registri degli eventi o altra documentazione relativa all'implementazione e al funzionamento del sistema di IA, che possa essere utilizzata per dimostrare che il sistema di IA viene utilizzato come previsto o per facilitare la comunicazione di preoccupazioni relative all'uso previsto del sistema di IA. Il periodo di conservazione dei registri degli eventi e di altra documentazione dipende dall'uso previsto del sistema di IA, dalle policy di conservazione dei dati dell'organizzazione e dai requisiti legali pertinenti in materia di conservazione dei dati.

B.10 Rapporti con terze parti e clienti

B.10.1 Obiettivo

Per garantire che l'organizzazione comprenda le proprie responsabilità e continui a rispondere delle proprie azioni, e che i rischi siano adeguatamente ripartiti quando terze parti sono coinvolte in qualsiasi fase del ciclo di vita del sistema di intelligenza artificiale.

B.10.2 Assegnazione delle responsabilità

Controllare

L'organizzazione dovrebbe garantire che le responsabilità all'interno del ciclo di vita del proprio sistema di intelligenza artificiale siano suddivise tra l'organizzazione stessa, i suoi partner, fornitori, clienti e terze parti.

Guida all'implementazione

Nel ciclo di vita di un sistema di IA, le responsabilità possono essere suddivise tra chi fornisce i dati, chi fornisce algoritmi e modelli, chi sviluppa o utilizza il sistema di IA, e chi è responsabile nei confronti di alcune o tutte le parti interessate. L'organizzazione dovrebbe documentare tutte le parti che intervengono nel ciclo di vita del sistema di IA e i loro ruoli, determinandone le responsabilità.

Laddove l'organizzazione fornisca un sistema di IA a terzi, deve garantire un approccio responsabile allo sviluppo del sistema. Si vedano i controlli e le linee guida di cui al [punto B.6](#). L'organizzazione deve essere in grado di fornire la documentazione necessaria (vedere [B.6.2.7](#) e [B.8.2](#)) per l'IA.

ISO/IEC 42001:2023(E)

sistema alle parti interessate rilevanti e alla terza parte a cui l'organizzazione fornisce il sistema di intelligenza artificiale.

Quando i dati trattati includono dati personali identificativi (PII), le responsabilità sono solitamente suddivise tra responsabili del trattamento e titolari del trattamento dei dati personali identificativi (PII). La norma ISO/IEC 29100 fornisce ulteriori informazioni sui responsabili del trattamento e sui titolari del trattamento dei dati personali identificativi (PII). Laddove sia necessario preservare la riservatezza dei dati personali identificativi (PII), è opportuno prendere in considerazione controlli come quelli descritti nella norma ISO/IEC 27701. In base alle attività di trattamento dei dati personali identificativi (PII) svolte dall'organizzazione e dal sistema di intelligenza artificiale (IA) e al ruolo dell'organizzazione nell'applicazione e nello sviluppo del sistema di IA durante il loro ciclo di vita, l'organizzazione può assumere il ruolo di titolare del trattamento dei dati personali identificativi (PII) (o di co-titolare del trattamento dei dati personali identificativi), di responsabile del trattamento dei dati personali identificativi (PII) o di entrambi.

B.10.3 Fornitori

Controllare

L'organizzazione dovrebbe stabilire un processo per garantire che l'utilizzo di servizi, prodotti o materiali forniti dai fornitori sia in linea con l'approccio dell'organizzazione allo sviluppo e all'uso responsabili dei sistemi di intelligenza artificiale.

Guida all'implementazione

Le organizzazioni che sviluppano o utilizzano un sistema di intelligenza artificiale possono avvalersi dei fornitori in vari modi, dall'approvvigionamento di set di dati, algoritmi o modelli di apprendimento automatico o altri componenti di un sistema come librerie software, fino all'intero sistema di intelligenza artificiale stesso da utilizzare da solo o come parte di un altro prodotto (ad esempio un veicolo).

Le organizzazioni dovrebbero prendere in considerazione diversi tipi di fornitori, cosa forniscono e il diverso livello di rischio che questo può rappresentare per il sistema e per l'organizzazione nel suo complesso nel determinare la selezione dei fornitori, i requisiti imposti a tali fornitori e i livelli di monitoraggio e valutazione continui necessari per i fornitori.

Le organizzazioni dovrebbero documentare il modo in cui il sistema di intelligenza artificiale e i componenti del sistema di intelligenza artificiale vengono integrati nei sistemi di intelligenza artificiale sviluppati o utilizzati dall'organizzazione.

Laddove l'organizzazione ritenga che il sistema di IA o i componenti del sistema di IA di un fornitore non funzionino come previsto o possano avere ripercussioni su individui o gruppi di individui, o entrambi, e sulla società non allineate all'approccio responsabile ai sistemi di IA adottato dall'organizzazione, l'organizzazione dovrebbe richiedere al fornitore di adottare misure correttive. L'organizzazione può decidere di collaborare con il fornitore per raggiungere questo obiettivo.

L'organizzazione deve garantire che il fornitore di un sistema di IA fornisca una documentazione appropriata e adeguata relativa al sistema di IA (vedere [B.6.2.7](#) e [B.8.2](#)).

B.10.4 Clienti

Controllare

L'organizzazione dovrebbe garantire che il suo approccio responsabile allo sviluppo e all'uso dei sistemi di intelligenza artificiale tenga conto delle aspettative e delle esigenze dei propri clienti.

Guida all'implementazione

L'organizzazione dovrebbe comprendere le aspettative e le esigenze dei clienti quando fornisce un prodotto o un servizio correlato a un sistema di intelligenza artificiale (ovvero quando è essa stessa un fornitore). Queste possono manifestarsi sotto forma di requisiti per il prodotto o il servizio stesso durante la fase di progettazione o ingegnerizzazione, oppure sotto forma di requisiti contrattuali o accordi generali di utilizzo. Un'organizzazione può avere molti tipi diversi di relazioni con i clienti, e ognuno di questi può avere esigenze e aspettative diverse.

L'organizzazione dovrebbe in particolare comprendere la natura complessa delle relazioni tra fornitori e clienti e capire dove la responsabilità ricade sul fornitore del sistema di intelligenza artificiale e dove sul cliente, continuando comunque a soddisfare esigenze e aspettative.

Ad esempio, l'organizzazione può identificare i rischi correlati all'uso dei suoi prodotti e servizi di intelligenza artificiale da parte del cliente e può decidere di gestire i rischi identificati fornendo al cliente le informazioni appropriate, in modo che quest'ultimo possa quindi gestire i rischi corrispondenti.

Come esempio di informazione appropriata, quando un sistema di IA è valido per un determinato dominio di utilizzo, i limiti di tale dominio devono essere comunicati al cliente. Si vedano i [paragrafi B.6.2.7 e B.8.2.](#) _____

ISO/IEC 42001:2023(E)

Allegato C (informativo)

Potenziali obiettivi organizzativi e fonti di rischio correlati all'IA

C.1 Generale

Questo allegato delinea i potenziali obiettivi organizzativi, le fonti di rischio e le descrizioni che possono essere prese in considerazione dall'organizzazione nella gestione dei rischi. Questo allegato non intende essere esaustivo né applicabile a tutte le organizzazioni. L'organizzazione dovrebbe determinare gli obiettivi e le fonti di rischio rilevanti. La norma ISO/IEC 23894 fornisce informazioni più dettagliate su questi obiettivi e fonti di rischio e sulla loro relazione con la gestione del rischio. La valutazione dei sistemi di IA, iniziale, periodica e quando giustificata, fornisce la prova che un sistema di IA viene valutato rispetto agli obiettivi organizzativi.

C.2 Obiettivi

C.2.1 Responsabilità

L'uso dell'IA può modificare gli attuali quadri di responsabilità. Laddove in precedenza le persone erano ritenute responsabili delle proprie azioni, ora queste possono essere supportate o basate sull'uso di un sistema di IA.

C.2.2 Competenza in materia di intelligenza artificiale

È necessaria una selezione di specialisti dedicati con competenze interdisciplinari ed esperienza nella valutazione, nello sviluppo e nell'implementazione di sistemi di intelligenza artificiale.

C.2.3 Disponibilità e qualità dei dati di formazione e di test

I sistemi di intelligenza artificiale basati sull'apprendimento automatico necessitano di dati di addestramento, convalida e test per addestrare e verificare i sistemi per il comportamento previsto.

C.2.4 Impatto ambientale

L'uso dell'intelligenza artificiale può avere impatti positivi e negativi sull'ambiente.

C.2.5 Equità

L'applicazione inappropriata dei sistemi di intelligenza artificiale per il processo decisionale automatizzato può rivelarsi ingiusta nei confronti di determinate persone o gruppi di persone.

C.2.6 Manutenibilità

La manutenibilità è correlata alla capacità dell'organizzazione di gestire le modifiche del sistema di intelligenza artificiale per correggere difetti o adattarsi a nuovi requisiti.

C.2.7 Riservatezza

L'uso improprio o la divulgazione di dati personali e sensibili (ad esempio cartelle cliniche) può avere effetti dannosi sugli interessati.

C.2.8 Robustezza

Nell'intelligenza artificiale, le proprietà di robustezza dimostrano la capacità (o l'incapacità) del sistema di avere prestazioni comparabili sui nuovi dati rispetto ai dati su cui è stato addestrato o ai dati di operazioni tipiche.

C.2.9 Sicurezza

La sicurezza si riferisce all'aspettativa che un sistema non determini, in determinate condizioni, uno stato in cui la vita umana, la salute, la proprietà o l'ambiente siano messi in pericolo.

C.2.10 Sicurezza

Nel contesto dell'intelligenza artificiale e in particolare per quanto riguarda i sistemi di intelligenza artificiale basati su approcci di apprendimento automatico (ML), occorre considerare nuove problematiche di sicurezza che vanno oltre le preoccupazioni classiche relative alla sicurezza delle informazioni e dei sistemi.

C.2.11 Trasparenza e spiegabilità

La trasparenza si riferisce sia alle caratteristiche di un'organizzazione che gestisce sistemi di intelligenza artificiale, sia ai sistemi stessi. La spiegabilità si riferisce alle spiegazioni dei fattori importanti che influenzano i risultati del sistema di intelligenza artificiale, fornite alle parti interessate in modo comprensibile per gli esseri umani.

C.3 Fonti di rischio

C.3.1 Complessità dell'ambiente

Quando i sistemi di intelligenza artificiale operano in ambienti complessi, dove la gamma di situazioni è ampia, può esserci incertezza sulle prestazioni e quindi una fonte di rischio (ad esempio, ambiente complesso di guida autonoma).

C.3.2 Mancanza di trasparenza e spiegabilità

L'incapacità di fornire informazioni adeguate alle parti interessate può essere fonte di rischio (ad esempio in termini di affidabilità e responsabilità dell'organizzazione).

C.3.3 Livello di automazione

Il livello di automazione può avere un impatto su vari ambiti di interesse, come la sicurezza, l'equità o la protezione.

C.3.4 Fonti di rischio legate all'apprendimento automatico

La qualità dei dati utilizzati per l'apprendimento automatico e il processo impiegato per raccogliarli possono essere fonti di rischio, in quanto possono avere un impatto su obiettivi quali sicurezza e robustezza (ad esempio a causa di problemi nella qualità dei dati o di avvelenamento dei dati).

C.3.5 Problemi hardware del sistema

Le fonti di rischio legate all'hardware includono errori hardware basati su componenti difettosi o sul trasferimento di modelli di apprendimento automatico addestrati tra sistemi diversi.

C.3.6 Problemi del ciclo di vita del sistema

Le fonti di rischio possono manifestarsi durante l'intero ciclo di vita del sistema di intelligenza artificiale (ad esempio, difetti di progettazione, implementazione inadeguata, mancanza di manutenzione, problemi di dismissione).

ISO/IEC 42001:2023(E)

C.3.7 Prontezza tecnologica

Le fonti di rischio possono essere correlate a tecnologie meno mature a causa di fattori sconosciuti (ad esempio limitazioni del sistema e condizioni al contorno, deriva delle prestazioni), ma anche dovute a tecnologie più mature a causa dell'autocompiacimento della tecnologia.

Allegato D

(informativo)

Utilizzo del sistema di gestione dell'intelligenza artificiale in tutti i settori e domini

D.1 Generale

Questo sistema di gestione è applicabile a qualsiasi organizzazione che sviluppi, fornisca o utilizzi prodotti o servizi che utilizzano un sistema di intelligenza artificiale. Pertanto, è potenzialmente applicabile a una vasta gamma di prodotti e servizi, in diversi settori, soggetti a obblighi, buone pratiche, aspettative o impegni contrattuali nei confronti delle parti interessate. Alcuni esempi di settori sono:

- salute;
- difesa;
- trasporto;
- finanza;
- occupazione;
- energia.

Per lo sviluppo e l'utilizzo responsabile di un sistema di IA, è possibile considerare diversi obiettivi organizzativi (vedere l'[Allegato C](#) per i possibili obiettivi). Questo documento fornisce requisiti e linee guida da una prospettiva specifica per la tecnologia di IA. Per molti dei potenziali obiettivi, esistono standard di sistema di gestione generici o specifici per settore. Questi standard di sistema di gestione considerano l'obiettivo solitamente da un punto di vista tecnologicamente neutrale, mentre il sistema di gestione dell'IA fornisce considerazioni specifiche per la tecnologia di IA.

I sistemi di IA non sono costituiti solo da componenti che utilizzano la tecnologia di IA, ma possono utilizzare una varietà di tecnologie e componenti. Lo sviluppo e l'utilizzo responsabili di un sistema di IA richiedono quindi di tenere conto non solo di considerazioni specifiche dell'IA, ma anche del sistema nel suo complesso, con tutte le tecnologie e i componenti utilizzati. Anche per quanto riguarda la parte specifica della tecnologia di IA, è necessario considerare altri aspetti oltre a considerazioni specifiche dell'IA. Ad esempio, poiché l'IA è una tecnologia di elaborazione delle informazioni, la sicurezza informatica si applica in generale ad essa. Obiettivi come sicurezza, protezione, privacy e impatto ambientale dovrebbero essere gestiti in modo olistico e non separatamente per l'IA e gli altri componenti del sistema. L'integrazione del sistema di gestione dell'IA con standard di sistema di gestione generici o specifici per settore relativi ad argomenti rilevanti è quindi essenziale per uno sviluppo e un utilizzo responsabili di un sistema di IA.

D.2 Integrazione del sistema di gestione dell'IA con altri standard di sistemi di gestione

Quando fornisce o utilizza sistemi di intelligenza artificiale, l'organizzazione può avere obiettivi o obblighi relativi ad aspetti che rientrano in altri standard di sistemi di gestione. Questi possono includere, ad esempio, sicurezza, privacy e qualità, ovvero argomenti trattati rispettivamente nelle norme ISO/IEC 27001, ISO/IEC 27701 e ISO 9001.

Quando si forniscono, si utilizzano o si sviluppano sistemi di intelligenza artificiale, i potenziali standard generici per i sistemi di gestione rilevanti, ma non limitati a questi, sono:

- ISO/IEC 27001: Nella maggior parte dei contesti, la sicurezza è fondamentale per raggiungere gli obiettivi dell'organizzazione con il sistema di intelligenza artificiale. Il modo in cui un'organizzazione persegue gli obiettivi di sicurezza dipende dal contesto e dalle proprie politiche. Se un'organizzazione identifica la necessità di implementare un sistema di gestione dell'intelligenza artificiale,

ISO/IEC 42001:2023(E)

e per affrontare gli obiettivi di sicurezza in modo altrettanto approfondito e sistematico, può implementare un sistema di gestione della sicurezza delle informazioni conforme alla norma ISO/IEC 27001. Dato che sia la norma ISO/IEC 27001 che i sistemi di gestione dell'IA utilizzano la struttura di alto livello, il loro utilizzo integrato è facilitato e di grande beneficio per l'organizzazione. In questo caso, le modalità di implementazione dei controlli che (in parte) riguardano la sicurezza delle informazioni in questo documento (vedere [B.6.1.2](#)) possono essere integrate con l'implementazione della norma ISO/IEC 27001 da parte dell'organizzazione.

- ISO/IEC 27701: In molti contesti e domini applicativi, le informazioni personali identificabili (PII) vengono elaborate da sistemi di intelligenza artificiale. L'organizzazione può quindi conformarsi agli obblighi applicabili in materia di privacy e alle proprie politiche e obiettivi. Analogamente, come per ISO/IEC 27001, l'organizzazione può trarre vantaggio dall'integrazione di ISO/IEC 27701 con il sistema di gestione dell'intelligenza artificiale. Gli obiettivi e i controlli relativi alla privacy del sistema di gestione dell'intelligenza artificiale (vedere [B.2.3](#) e [B.5.4](#)) possono essere integrati con l'implementazione di ISO/IEC 27701 da parte dell'organizzazione.
- ISO 9001: Per molte organizzazioni, la conformità alla norma ISO 9001 è un segno chiave di orientamento al cliente e di reale attenzione all'efficacia interna. La valutazione indipendente della conformità alla norma ISO 9001 facilita il business tra le organizzazioni e ispira fiducia nei clienti nei prodotti o nei servizi. Il livello di fiducia dei clienti in un'organizzazione o in un sistema di intelligenza artificiale può essere notevolmente rafforzato quando un sistema di gestione dell'intelligenza artificiale viene implementato congiuntamente alla norma ISO 9001, quando sono coinvolte tecnologie di intelligenza artificiale. Il sistema di gestione dell'intelligenza artificiale può essere complementare ai requisiti della norma ISO 9001 (gestione del rischio, sviluppo software, coerenza della catena di fornitura, ecc.) aiutando l'organizzazione a raggiungere i propri obiettivi.

Oltre agli standard generici sui sistemi di gestione sopra menzionati, un sistema di gestione dell'IA può anche essere utilizzato congiuntamente a un sistema di gestione dedicato a un settore specifico. Ad esempio, sia la ISO 22000 che un sistema di gestione dell'IA sono rilevanti per un sistema di IA utilizzato per la produzione, la preparazione e la logistica alimentare. Un altro esempio è la ISO 13485. L'implementazione di un sistema di gestione dell'IA può supportare i requisiti relativi al software per dispositivi medici previsti dalla ISO 13485 o da altri standard. Standard internazionali del settore medico come IEC 62304.

Bibliografia

- [1] ISO 8000-2, *Qualità dei dati — Parte 2: Vocabolario*
- [2] ISO 9001, *Sistemi di gestione della qualità — Requisiti*
- [3] ISO 9241-210, *Ergonomia dell'interazione uomo-sistema — Parte 210: Progettazione incentrata sull'uomo per sistemi interattivi*
- [4] ISO 13485, *Dispositivi medici — Sistemi di gestione della qualità — Requisiti per scopi normativi*
- [5] ISO 22000, *Sistemi di gestione per la sicurezza alimentare — Requisiti per qualsiasi organizzazione nella filiera alimentare*
- [6] IEC 62304, *Software per dispositivi medici — Processi del ciclo di vita del software*
- [7] Guida ISO/IEC 51, *Aspetti di sicurezza — Linee guida per la loro inclusione negli standard*
- [8] ISO/IEC TS 4213, *Tecnologia dell'informazione — Intelligenza artificiale — Valutazione delle prestazioni di classificazione dell'apprendimento automatico*
- [9] ISO/IEC 5259 (tutte le parti2), *Qualità dei dati per l'analisi e l'apprendimento automatico (ML)*
- [10] ISO/IEC 5338, *Tecnologia dell'informazione — Intelligenza artificiale — Processo del ciclo di vita del sistema di intelligenza artificiale*
- [11] ISO/IEC 17065, *Valutazione della conformità — Requisiti per gli organismi che certificano prodotti, processi e servizi*
- [12] ISO/IEC 19944-1, *Cloud computing e piattaforme distribuite y Flusso di dati, categorie di dati e dati uso — Parte 1: Fondamenti*
- [13] ISO/IEC 23053, *Quadro per sistemi di intelligenza artificiale (IA) che utilizzano l'apprendimento automatico (ML)*
- [14] ISO/IEC 23894, *Tecnologia dell'informazione — Intelligenza artificiale — Guida alla gestione del rischio*
- [15] ISO/IEC TR 24027, *Tecnologia dell'informazione — Intelligenza artificiale (IA) — Distorsione nei sistemi di IA e*
Processo decisionale assistito dall'intelligenza artificiale
- [16] ISO/IEC TR 24029-1, *Intelligenza artificiale (IA) — Valutazione della robustezza delle reti neurali — Parte 1: Panoramica*
- [17] ISO/IEC TR 24368, *Tecnologia dell'informazione — Intelligenza artificiale — Panoramica delle questioni etiche e preoccupazioni sociali*
- [18] ISO/IEC 25024, *Ingegneria dei sistemi e del software — Requisiti di qualità dei sistemi e del software e valutazione (SQuaRE) — Misurazione della qualità dei dati*
- [19] ISO/IEC 25059, *Ingegneria del software — Requisiti di qualità dei sistemi e del software e*
Valutazione (SQuaRE) — Modello di qualità per i sistemi di intelligenza artificiale
- [20] ISO/IEC 27000:2018, *Tecnologia dell'informazione — Tecniche di sicurezza — Sicurezza delle informazioni sistemi di gestione — Panoramica e vocabolario*
- [21] ISO/IEC 27701, *Tecniche di sicurezza — Estensione a ISO/IEC 27001 e ISO/IEC 27002 per la privacy gestione delle informazioni — Requisiti e linee guida*
- [22] ISO/IEC 27001, *Sicurezza delle informazioni, sicurezza informatica e tutela della privacy — Sistemi di gestione della sicurezza delle informazioni — Requisiti*
- [23] ISO/IEC 29100, *Tecnologia dell'informazione — Tecniche di sicurezza — Quadro di riferimento per la privacy*

ISO/IEC 42001:2023(E)

- [24] ISO 31000:2018, *Gestione del rischio — Linee guida*
- [25] ISO 37002, *Sistemi di gestione del whistleblowing — Linee guida*
- [26] ISO/IEC 38500:2015, *Tecnologia dell'informazione – Governance dell'IT per l'organizzazione*
- [27] ISO/IEC 38507, *Tecnologia dell'informazione — Governance dell'IT — Implicazioni di governance dell'uso dell'intelligenza artificiale da parte delle organizzazioni*
- [28] Lifecycle DDI 3.3, 15/04/2020. Data Documentation Initiative (DDI) Alliance. [consultato il 19/02/2022]. Disponibile all'indirizzo: <https://ddialliance.org/Specification/DDI-Lifecycle/3.3/>
- [29] Risk Framework NIST-AI 1.0, 26 gennaio 2023. National Institute of Technology (NIST) [consultato il 17 aprile 2023] <https://www.nist.gov/itl/ai-risk-management-framework>

